The Influence of ISO 27001 Standards on Agile Methodology:

Trade-offs and Implications

Vahid Naserinia

Sami Ullah

Master's Degree Project in
IT Project Management
Spring term 2025
Supervisor: Gunnar Wettergren
Department of Computer
and Systems Sciences

Stockholm
University

Abstract

This study investigates the challenge of balancing the structured security requirements of ISO/IEC 27001 with the flexibility of Agile methodologies. Through qualitative case studies of a mid-sized IT enterprise ("TechSME") and a multinational financial institution ("BankCorp"), supplemented by interviews with 12 industry professionals, the research explores how organizations reconcile compliance with innovation. The analysis is framed by sociotechnical systems theory, emphasizing the interdependence of social (people, culture) and technical (tools, processes) subsystems. Lean Security principles support minimizing bureaucratic waste while maintaining robust security controls.

The research is guided by the question: "How does the integration of ISO 27001 influence Agile software development practices in organizations of different sizes?" The findings show that ISO 27001 integration influences Agile practices differently depending on organizational scale. In Small-to-Medium Enterprises (SMEs), the standard drives lightweight, iterative processes such as incremental documentation, risk-driven checklists, and "security champion" roles that embed compliance into Agile workflows while preserving flexibility. In contrast, Multinational Enterprises (MNEs) employ formalized, technology-enabled approaches, including automation (e.g., CI/CD pipelines with embedded security scanning), Compliance-as-Code (CaC), and centralized governance to align Agile processes with ISO 27001 controls at scale.

This study proposes a tailored framework for integrating ISO 27001 with Agile methods, demonstrating that agility and compliance coexist when security is treated as a shared responsibility and processes are adapted to the context. These insights contribute to understanding how organizations can innovate rapidly while ensuring robust security compliance.

Keywords: Agile-ISO 27001 integration, Security-compliance trade-offs, DevSecOps automation, Sociotechnical systems theory, Organizational culture, Hybrid Agile-compliance models.

Acknowledgements

We want to express our deepest gratitude to our supervisor, Gunnar Wettergren, for his insightful guidance, steady encouragement, and constructive feedback throughout this thesis. His expertise and thoughtful mentorship have been instrumental in shaping and completing this work.

We also thank Frithjof Stöppler for his academic inspiration and valuable contributions during our studies. His engaging lectures and critical perspectives have profoundly influenced our understanding of the subject.

Vahid extends his heartfelt thanks to his wife, Liza, for her unwavering love, support, patience, and encouragement throughout this academic journey. Her belief in this endeavor has been a constant source of strength.

Sami would like to express his deepest gratitude to his wife, Alvina, for her love, support, and patience, which have been a source of motivation and inspiration. He is also sincerely thankful to his parents for their steadfast support, guidance, and encouragement throughout his academic path.

Finally, we would like to thank our families, friends, and all participants who generously contributed their time and insights to this research. Their support and involvement have been invaluable.

Abbreviations

Abbreviation	Description
AI	Artificial Intelligence
API	Application Programming Interface
CaC	Compliance-as-Code
CI/CD	Continuous Integration/Continuous Deployment
COBIT	Control Objectives for Information and Related Technologies
DAST	Dynamic Application Security Testing
DevSecOps	Development, Security, and Operations
DoD	Definition of Done
ERP	Enterprise Resource Planning
EU	European Union
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
IEC	International Electrotechnical Commission
IoT	Internet of Things
ISMS	Information Security Management Systems
ISO	International Organization for Standardization
IT	Information Technology
LLMs	Large Language Models
LMS	Learning Management System
MNE	Multinational Enterprise

NGOs	Non-Governmental Organizations
NIST	National Institute of Standards and Technology
NPO	Non-profit Organisation
OpenVAS	Open Vulnerability Assessment Scanner
OWASP	Open Worldwide Application Security Project
PDCA	Plan-Do-Check-Act
PHI	Personal Health Information
PX	Participant[X] (e.g., P1... for anonymized interviewees)
SAAD	Security-Aware Agile Development
SAST	Static Application Security Testing
SBOM	Software Bill of Materials
SIEM	Security Information and Event Management
SME	Small and Medium-sized Enterprise
SVM	Security Vulnerability Management
VUCA	Volatility, Uncertainty, Complexity and Ambiguity
ZTA	Zero Trust Architecture

List of Tables

2.1 SME vs. Enterprise Integration Strategies 10
2.2 Comparison of Agile and ISO 27001 Philosophies 11

3.1 Challenges vs. Solutions in Balancing Agile and ISO 27001 . . 36

4.1 Key Recommendations 40
4.2 Tooling and Automation 41
4.3 Tools & Techniques Across Participants 41
4.4 Cultural and Behavioral Shifts 42
4.5 Resource Constraints and Adaptations 43
4.6 Process Integration 43
4.7 Cross-Industry Strategies for Agile–ISO 27001 Balance 44
4.8 Cross-Functional Collaboration 44

6.1 Influences of ISO 27001 Integration on Agile Practices 50

C.1 Annex A Control Domains (Cited in This Thesis) 65

D.1 ISO/IEC 27001:2022 (Clauses Cited in This Thesis) 67

Contents

Abstract **iii**

Acknowledgements **v**

Abbreviations **vii**

List of Tables **ix**

Contents **xi**

1 Introduction **1**
1.1 Background 2
1.2 Problem 3
1.3 Research Question and Analytical Dimensions 4
1.4 Delimitations 5
1.5 Structure of the Thesis 5

2 Extended Background **7**
2.1 Agile Methodologies: A Paradigm of Flexibility and Security Gaps 7
2.2 ISO 27001: A Structured Approach to Security and Its Sociotechnical Tensions 8
2.3 The Trade-Off Between Agility and Compliance: Reconciling Divergent Paradigms 10
2.3.1 Core Tensions and Theoretical Underpinnings, Philosophical Contrasts: 11
2.4 Integrating Security into Agile Frameworks: Strategies for Socio-Technical Alignment 13
2.4.1 Security-Focused User Stories: Bridging Functional and Non-Functional Requirements 13

2.4.2 Automation and Tooling: Scaling Compliance in CI/CD Pipelines 14
2.4.3 Cultural Adaptation: Training and Security Champions 15
2.4.4 Hybrid Models: Balancing Legacy Systems and Agile Innovation 15
2.4.5 Theoretical and Practical Synthesis 15
2.5 Case Studies and Empirical Evidence: Synthesizing Contextual Insights 16
2.5.1 Financial Sector: Balancing Rigor and Speed 16
2.5.2 Healthcare: Security Sprints and Proactive Compliance 16
2.5.3 Cross-Industry SME Strategies: Flexibility Over Formality 17
2.5.4 Enterprise Scale: Automation and Governance 18
2.5.5 Theoretical Synthesis: Sociotechnical Alignment in Practice 18
2.6 Theoretical Perspectives: Bridging Agile and Compliance Through Sociotechnical Frameworks 18
2.6.1 Sociotechnical Systems Theory: Interdependence of People, Tools, and Processes 19
2.6.2 Institutional Theory: Compliance as a Strategic Imperative in Regulated Industries 19
2.6.3 Lean Security: Minimizing Waste, Maximizing Value . 20
2.6.4 DevSecOps and Adaptive Governance: Scaling Compliance in Agile Environments 20
2.6.5 Synthesis: Toward a Contextual Theoretical Framework 21
2.7 Challenges and Considerations: Navigating the Agile-ISO 27001 Integration Landscape 21
2.7.1 Cultural Resistance and Misalignment 21
2.7.2 Documentation Overhead 22
2.7.3 Resource Constraints in SMEs 22
2.7.4 Evolving Threat Landscape 23
2.7.5 Governance vs. Autonomy 23
2.7.6 Tooling and Automation Costs 23
2.8 Future Directions: Emerging Trends and Research Opportunities 24
2.8.1 AI and Machine Learning in Compliance Automation 24
2.8.2 Sector-Specific Frameworks for Regulated Industries 24
2.8.3 SME-Centric Solutions: Bridging Resource Gaps . . . 25
2.8.4 Longitudinal and Behavioral Studies 25

2.8.5 Zero Trust and Agile Integration 26
2.8.6 Cultural and Psychological Dimensions 26

3 Methodology **29**
3.1 Research Design 30
3.2 Case Selection Criteria 31
3.3 Case Boundaries and Operational context 32
3.3.1 TechSME 32
3.3.2 BankCorp 33
3.4 Data Collection Methods 33
3.4.1 Document Analysis 33
3.4.2 Semi-Structured Interviews 34
3.4.3 Direct Observations 35
3.5 Data Analysis Strategy 35
3.6 Reliability and Validity 36
3.7 Ethical Considerations 37
3.8 Delimitations 37
3.9 Note on AI-assisted Editing 38
3.10 Summary 38

4 Results **39**
4.1 Trade-Offs Between Agility and Compliance 39
4.2 Strategies for Integration 40
4.2.1 Security-Focused User Stories 40
4.2.2 Automation and Tooling 41
4.2.3 Cultural Adaptation 42
4.3 Challenges and Mitigation 42
4.4 Success Factors 43
4.5 Summary of Empirical Results 43

5 Discussion **45**
5.1 Reconciling Flexibility and Compliance 46
5.2 Strategic Adaptations in Practice 46
5.3 The Role of Organizational Culture 47
5.4 Implications for Practice 48
5.5 Methodological Reflections: Reliability and Validity 48

6 Conclusion **49**
6.1 Summary of Key Findings 50
6.2 Contributions 51

6.3 Limitations and Future Research 51
6.4 Final Statement 52

Bibliography **58**

A Participant Consent Form (GDPR-Compliant) **61**

Appendices **61**

B Semi-Structured Interview Guide **63**

C ISO/IEC 27001:2022 Annex A Control Domains **65**

D Key ISO/IEC 27001:2022 Clauses **67**

1

Introduction

As organizations push for fast innovation, they are under increasing pressure to protect their information security appropriately. Agile methodologies, emphasizing flexibility, collaboration, and iterative progress, have become a cornerstone of IT project management (Valdés-Rodríguez et al., 2023). However, integrating Agile practices with the rigid requirements of ISO/IEC 27001, a security management standard, is challenging. ISO 27001, well-known worldwide for the Information Security Management System (ISMS), requires extensive documentation, systematic risk assessment, and ongoing supervision, which may displease Agile methodologies' rapid and low-bureaucratic character (Dumont et al., 2021).

Synchronization between agile practices and security compliance is critical in areas where timely product development has to be controlled within the parameters of strict security standards. With the increasing digitalization of business processes and the persistent rise in cyberattacks, security and compliance have become critically important for organizations. At the same time that these pressures are mounting, customer expectations call for the rapid cadence of the product life-cycle, constant improvement, and quick delivery of service and software. Organizations commonly struggle to balance Agile flexibility with the strict documentation and control requirements mandated by ISO 27001. The challenge of modifying Agile practices to comply with ISO 27001 has remained an ongoing dilemma for organizations that wish to manage as much security rigor as they can and still be able to deal with operational agility. Balancing security requirements with operational flexibility is essential; overly rigid processes can

slow development, while excessively lenient controls may expose organizations to greater risks. This study will find out how companies address this balance and include security in Agile processes with the ultimate goal of providing real-life recommendations for augmenting security and operational effectiveness. Drawing from a rigorous methodology incorporating theoretical research and the analysis of case studies and conversations with industry professionals, this thesis seeks to advance knowledge of how Agile and ISO 27001 could coexist successfully in real organizational environments.

1.1 Background

Methods like Scrum and Kanban, under Agile, involve iterative development as well as interactive customer involvement, which welcomes agile innovation in adaptable business conditions (Beck et al., 2001). As a direct response to the inadequacies of the conventional waterfall approach, Agile models such as Scrum and Kanban have grown tremendously popular in different industries (Schwaber and Sutherland, 2020). The Agile Manifesto, in its emphasis on human interaction and collaboration over rigid processes and tools, has dramatically changed the way teams approach issues and deliver value (Fowler, Highsmith, et al., 2001). This flexibility of Agile in giving feedback repeatedly, accepting iterative development, and allowing changes in needs makes it a perfect fit for industries that undergo constant changes. However, ISO 27001 establishes a well-structured procedure for protecting critical data to ensure confidentiality, integrity, and availability (ISO/IEC, 2022). ISO 27001 certification reveals an organization's focus on sensitive security measures, which contributes to strengthening customer trust and meeting regulatory conditions (Dumont et al., 2021). However, the strict rules and specifics required by ISO 27001 often run counter to Agile's approach of adaptability and loose documentation. ISO 27001 certification demands that organizations make risk evaluations, document security practices, implement broad controls, and undergo independent audits. These actions form additional stages that may hinder Agile benefits unless incorporated in Agile contexts. (Stewart, 2023) Cybersecurity is an intrinsic part of digital transformation and indicates the urgent need to combine Agile practices with ISO 27001 protections. It is not easy for companies to integrate Agile methodologies with the ISO 27001's compliance requirements. The Agile process underscores the necessity of delivering working software over extensive documentation. However, ISO

27001 requires that specific records have to be kept to confirm compliance with security controls. Some organizations have reacted to the tension between agility and compliance by adopting hybrid models that incorporate security controls seamlessly into Agile processes.

However, the success of such approaches is context-specific to certain organizational settings, and more research is needed to explain the best balance between the trade-offs. On the other hand, ISO 27001 mandates rigorous risk assessments and extensive documentation for data protection, an obligation that often conflicts with Agile's desire for little regulatory control (ISO/IEC, 2022). This is particularly critical in areas such as finance and healthcare, which require strict regulatory provisions. For instance, TechSME, which specializes in providing IT services, prioritizes process acceleration over detailed documentation, which causes compliance problems (Moyon et al., 2020; Smith et al., 2022).

The research uses the sociotechnical systems theory to study how businesses implement technical controls, such as automated compliance tools, and human considerations, such as team culture. Under this model, the attainment of secure agility would require the synergy of all people, processes, and technical systems (Baxter and Sommerville, 2011).

1.2 Problem

The combination of Agile methods and traditional Information Security standards like ISO 27001 can prove highly challenging. ISO 27001 provides a worldwide standard for information security management, which requires in-depth documentation, strict risk analysis, and constant monitoring. Although the rigorous specifications of ISO 27001 require extensive documentation, this may be at loggerheads with Agile's emphasis on acceleration of work and reduction of bureaucracy (Dumont et al., 2021). Balancing the requirements of regulatory compliance and necessitating quick, agile product development is critical for firms that work in security-sensitive industries with rapid cycles. As companies continue to digitize and face rising cybersecurity problems, strong security and compliance with regulations have become critical.

Meanwhile, there is an increased demand for organizations to produce and provide products and services faster, with consistent improvements and short-cycle building. Complying with the need for agile practices and the minute requirements and documented controls of ISO 27001 is a common problem among organizations. The integration of ISO 27001 and Agile

procedures presents a significant challenge to firms wanting to integrate security and operating efficiency. Balancing the compliance requirement with fostering agility is critical. Too much strictness with regard to security may hamper innovation, but too much flexibility may present an opportunity for vulnerabilities. The purpose of this research is to identify effective ways to integrate security into Agile frameworks and to provide practical guidance to organizations seeking to enhance security and operational efficiency. The goal of this thesis is to demonstrate the ways in which organizations can manage to harmonize Agile and ISO 27001 practices in practice with the help of the implementation of a solid methodology, which includes theoretical analysis, case studies in the real world, and dialogue with practitioners.

1.3 Research Question and Analytical Dimensions

This study investigates the integration of ISO 27001 within Agile software development practices, aiming to understand how organizations of varying sizes adapt their methodologies to achieve flexibility and compliance. The primary research question guiding this study is:

- **How does the integration of ISO 27001 influence Agile software development practices in organizations of different sizes?**

To answer this question, the research analyzes several key dimensions:

- Cultural Adaptation: How roles such as security champions and training practices influence team alignment.
- Tooling and Automation: The impact of SAST/DAST tools, CI/CD pipelines, and compliance automation.
- Organizational Scale Differences: Comparative strategies between SMEs and multinational enterprises.
- Governance and Documentation Practices: How organizations balance agility with the rigorous documentation and control requirements of ISO 27001.

These analytical dimensions shape the data collection and the structure of the findings and discussion.

1.4 Delimitations

This study is delimited by several intentional boundaries set to ensure focus and feasibility.

- Geographic Focus: The research is limited to organizations operating in Sweden, which share a common legal and regulatory environment (e.g., GDPR compliance), influencing how ISO 27001 is interpreted and applied.
- Organizational Focus: The study includes two case organizations: a SME in the IT sector (TechSME) and an MNE in the financial sector (BankCorp). The findings, therefore, reflect the practices and constraints relevant to these two specific contexts and may not generalize to public sector institutions, Non-governmental organizations (NGOs), or organizations outside Sweden.
- Thematic Focus: This research specifically explores the integration of ISO/IEC 27001 information security management standards with Agile software development practices. Other standards, such as the National Institute of Standards and Technology (NIST) or Control Objectives for Information and Related Technologies (COBIT), are not included in the analysis.
- Temporal Scope: The study investigates early to mid-stage ISO 27001 adoption, focusing on how integration efforts impact Agile development practices during implementation. It does not assess long-term post-certification impacts or the sustainability of compliance measures.
- Role Focus: The study centers on perspectives from security managers, developers, product owners, and Agile coaches involved in ISO 27001 implementation. Perspectives from external auditors or end users are not included.

These delimitations were made to maintain a clear analytical scope and to ensure that data collection and analysis could be completed within the timeframe of a one-year master's thesis.

1.5 Structure of the Thesis

The remainder of this thesis is structured as follows. Chapter 2 provides an extended background and literature review, introducing relevant theories

such as sociotechnical systems theory and Lean Security and highlighting the challenges of integrating ISO 27001 with Agile methods. Chapter 3 outlines the research design and methodology, detailing the qualitative case study approach, data collection techniques, and considerations of reliability and ethics. Chapter 4 presents the empirical findings from the two case studies, TechSME and BankCorp, organized around key themes. Chapter 5 discusses the findings, connecting them to the theoretical frameworks and prior research. Finally, Chapter 6 concludes the thesis by summarizing the main contributions, implications, limitations, and suggestions for future research.

2

Extended Background

The combination of Agile methodologies with ISO 27001 standards creates a fascinating balance between adaptability and the need for structured security measures. In this chapter, we explore the theoretical underpinnings and real-world studies that shed light on this connection, offering a thorough understanding of the trade-offs and synergies at play.

2.1 Agile Methodologies: A Paradigm of Flexibility and Security Gaps

The application of Scrum and Kanban within Agile methodologies provides robust support for iterative development, collaboration, and flexible processes. They allow organizations to react quickly to changing needs (Beck et al., 2001). Consistent with the Agile Manifesto's emphasis on individuals and interactions over processes and tools, Agile frameworks have fundamentally transformed software development practices. They substituted traditional rigid processes with a phased approach focused on delivering results and receiving customer feedback (Fowler, Highsmith, et al., 2001; Schwaber and Sutherland, 2020). This agility leads to a boom in innovation, particularly in fast-changing fields such as IT services, where TechSMEs emphasize Agile's success through their simplified methods (Chapter 4). However, this flexibility can sometimes lead to security issues. By focusing on rapid releases and avoiding thorough documentation, the chances of security planning being compromised rise, and sensitive data systems are

exposed (Akhtar, 2025; Kocot and Szyma'nska, 2025). The Agile methodology might focus on rapid software delivery rather than thorough risk analysis, which often leads to the consideration of security issues only after they occur, a reactive approach (Siponen and Willison, 2009). The issue of reactive documentation within TechSME is explored in (Chapter 4), highlighting how delayed documentation practices contributed to security lapses during audits. Fortunately, the progress in such methods as DevSecOps and Lean Security is narrowing the gap between agility and security. DevSecOps combines development, security, and operations with automated security testing (Continuous Integration/Continuous Deployment (CI/CD), integrated Static Application Security Testing (SAST), and Dynamic Application Security Testing (DAST)). This approach enables timely vulnerability identification without slowing Agile's fast development cycle (Fitzgerald and Stol, 2017; Thool and Brown, 2024). Lean Security, however, focuses on minimizing bureaucracy in favor of strong controls, a strategy that smaller businesses like TechSMEs adopt by conducting regular compliance reviews (Assal and Chiasson, 2019; Moyon et al., 2020). Looking at these obstacles from the perspective of sociotechnical systems helps to understand the dynamic tensions involved. The focus on people in Agile approaches sometimes clashes with ISO 27001's detailed standards, which require companies to change their organizational culture by introducing security experts in order to reconcile the flexibility of teams with governance requirements (Baxter and Sommerville, 2011). Take BankCorp, for instance; BankCorp's use of automated compliance solutions is a smart way to overcome sociotechnical barriers, providing a fine balance between independent developers and centralized control (Kauko, 2025) Some experts question old sales-oriented growth strategies, instead promoting Agile's product development focus to encourage innovation, a strategy that is demonstrated in TechSME's customer-centered sprint planning (Bremer et al., 2025). It is recommended that for Agile to be effective in large organizations, the organization of governance needs to be rethought, as is the case with BankCorp's dual use of Agile and waterfall approaches to manage legacy systems.

2.2 ISO 27001: A Structured Approach to Security and Its Sociotechnical Tensions

The ISO 27001 standard provides a trusted approach to developing, implementing, and maintaining an Information Security Management System

(ISMS). ISO 27001 is a risk-based, detailed documentation and continuous improvement using the PDCA approach (Culot et al., 2021; ISO/IEC, 2022). With the prescription of approved risk controls as listed in (Appendix C), By mandating formal risk assessment, established controls (Appendix C)), and external audit, this standard allows organizations to meet regulatory requirements like GDPR and HIPAA, and increase customer confidence through clear security measures (Moyon et al., 2020; Sharma and Dash, 2012). The ISO 27001 certification is an important competitive advantage for institutions such as BankCorp, representing the institutional theory focus on formal governance in highly regulated environments (Dumont et al., 2021).

On the other hand, the formal structure of ISO 27001 can sometimes clash with Agile's speedy delivery processes. ISO 27001's emphasis on thorough record-keeping and central authority frequently leads to administrative bottlenecks, something that TechSME, because of its limited resources, struggles to handle, particularly in terms of audit trails or assembling compliance personnel (Culot et al., 2021; Munir, 2024). For example, TechSME had problems implementing ISO 27001, which led to documentation delays and slowed sprint deliverables, a situation familiar to Agile's focus on functional software over comprehensive documentation (Beck et al., 2001).

Furthermore, unwillingness to change the company's culture may impede ISO 27001 implementation. ISO 27001's regulations may be seen as an intrusion into agile teams' autonomy, leading to conflicts between developers and auditors (Valdés-Rodríguez et al., 2023). This divide shows the key concepts of the sociotechnical systems theory, highlighting the necessity of people and technology collaboration. On the contrary, while ISO 27001 is procedural, Agile focuses on empowering teams and fast iteration cycles (Baxter and Sommerville, 2011). To solve this problem, BankCorp introduced compliance officers to Agile ceremonies like sprint reviews, which helped to promote cooperation and ease the tension between development and auditors. (Podrecca, 2023) study reveals the contradictions of introducing ISO 27001 into an organizational system, illustrating BankCorp's approach to combining Agile flexibility and centralized control.

Meanwhile, smaller entities embracing budget solutions, such as Trivy and Wazuh, are willing to accept that this may lead to less accurate results (Chapter 4). Hybrid methodologies are also used, which allow the combination of the strict requirements of ISO 27001 with the flexibility of Agile by introducing iterative compliance models that distribute risk assessment documentation over sprints rather than doing it all at once (Moyon et al.,

2020). TechSMEs show how Lean Security and Agile waste minimization principles can be applied by introducing gamified "Security Champion" roles (Assal and Chiasson, 2019). Cultural adaptation is key here; Effective training initiatives and leadership guidance are significant. BankCorp has enforced adherence through compulsory workshops, and TechSMEs have facilitated security ownership through badge systems (Rindell et al., 2021). The challenges of ISO 27001 show the necessity of effective sociotechnical alignment. The technical solutions of the standard can be there.

However, its final value depends on cultural adaptations such as the collaborative efforts between developers and auditors to reconcile the independence of the Agile method with the governance structures of ISO (Baxter and Sommerville, 2011). For instance, BankCorp's use of AI-powered risk-scoring tools allows decentralized teams to focus on priority controls without losing agility

Table 2.1: SME vs. Enterprise Integration Strategies

Aspect	**SME (TechSME)**	**Enterprise (BankCorp)**
Documentation	Lightweight checklists, retroactive updates	Automated templates, real-time traceability
Tooling	Open-source (Trivy, Wazuh)	SAST/DAST tools, AI-driven automation
Cultural Adaptation	Gamification, part-time security champions	Mandatory training, centralized governance
Compliance Focus	Iterative alignment	Rigorous audit readiness

2.3 The Trade-Off Between Agility and Compliance: Reconciling Divergent Paradigms

It is not easy to adjust Agile practices to ISO 27001 standards, primarily due to the significant differences in their underlying principles and implementation approaches. Agile focuses on adaptability, frequent iterations, and team decision-making, while ISO 27001 emphasizes formal governance, extensive documentation, and proactive risk management (Dumont et al., 2021). This generates a complex sociotechnical environment that demands organizations to reconcile innovation with security, speed

with stability, and team autonomy with the necessary oversight. The trade-offs between these philosophies are well exemplified by the contrasting approaches taken by TechSME (SME) and BankCorp (MNE) as presented in this study.

2.3.1 Core Tensions and Theoretical Underpinnings, Philosophical Contrasts:

Table 2.2: Comparison of Agile and ISO 27001 Philosophies

Agile Philosophy	ISO 27001 Philosophy	Key Tension
Iterative development	Rigorous documentation	Agile emphasizes rapid cycles, while ISO 27001 demands detailed records.
Minimal bureaucracy	Formal risk assessments	Agile avoids red tape; ISO 27001 requires systematic risk analysis.
Customer collaboration	Regulatory compliance	Agile prioritizes user feedback; ISO 27001 focuses on meeting audit standards.
Responding to change	Structured controls	Agile welcomes evolving requirements; ISO 27001 enforces predefined controls.
Working software over processes	Process adherence	Agile values functional outcomes; ISO 27001 prioritizes procedural compliance.
Team autonomy	Governance structures	Agile empowers teams; ISO 27001 requires centralized oversight.

Agile's Ethos: Agile prioritizes functional software over detailed documentation and is more flexible than rigidly following a plan (Beck et al., 2001). This approach facilitates rapid iterations, as demonstrated by TechSME's use of streamlined checklists to accelerate sprint planning. However, poor record-keeping may create gaps in audit trails, prompting teams to review and revise their processes later.

ISO 27001's focus on detailed controls may lead to technical debt as it is reactive (Moyon et al., 2020). The most important philosophical differences between Agile and ISO 27001 are summarized in Table 2.2 ISO 27001's Rigor: ISO 27001 stresses a thorough risk analysis (Clause 8 (Appendix D, Table D.1)) and copious record-keeping of controls (Clause 7 (Appendix D, Table D.1)), which ensures compliance but can lead to bureaucratic inefficiencies. BankCorp is a prime example of this, as they postponed a critical encryption upgrade by three days to finish an official risk assessment, demonstrating the pitfalls of inflexible compliance requirements in dynamic environments (Smith et al., 2022).

These barriers indicate the applicability of sociotechnical systems theory, which emphasizes the need to coordinate technical processes (e.g.,

automated compliance tools) with organizational and social factors (i.e., team culture) for effective integration (Baxter and Sommerville, 2011). TechSME's gamified "Security Champion" initiative exemplifies this fine line, encouraging collective compliance without sacrificing agility. Governance vs. Autonomy: Agile implementation enables teams to self-organize, promoting innovation, as demonstrated in BankCorp's developer-led CI/CD workflows. However, ISO 27001 requires centralized governance to ensure uniform policy compliance, which can lead to conflicts when changes require prior approval, as observed by (Valdés-Rodríguez et al., 2023). BankCorp solved these conflicts by involving auditors in sprint reviews, which bridged the gap between strict security controls and Agile timelines. Iterative Development vs. Stable Requirements: Agile's iterative nature is flexible to changing user needs, but this can conflict with the rigid stability requirements that ISO 27001 enforces to ensure predictable processes.

This challenge is most prominent in industries with strict regulations, such as healthcare, where the need to keep up with updates to comply with HIPAA needs to be balanced with Agile's flexible methods (Thool and Brown, 2024). BankCorp addressed these issues by adopting a hybrid approach, with separate management of legacy systems with waterfall processes and Agile APIs and mandatory "ISO Sync" sessions to ensure coordination. Now, let us discuss practical experiences and methods of dealing with these trade-offs. Case studies and scholarly publications provide evidence of context-specific solutions. TechSMEs have embraced Lean Security Adaptations to make their approach more streamlined. TechSME overcame this challenge by implementing an iterative compliance strategy, using sprint retrospectives to document risks incrementally, which is closely aligned with Lean principles aimed at waste reduction (Assal and Chiasson, 2019).

However, they faced tooling constraints. They embraced open-source tools such as Trivy because of budget constraints, but developers reported that these tools did not consistently deliver the same level of precision as commercial alternatives (Chapter 4). Big enterprises such as BankCorp have highlighted automation at scale as a key solution. By incorporating SAST/DAST tools into their CI/CD workflows, they have automated 40% of compliance testing and significantly reduced manual effort (Fitzgerald and Stol, 2017). The use of AI in their risk-scoring system has allowed for a focus on high-impact controls, which aligns with the adaptive governance principles proposed by the sociotechnical theory (Asprion et al., 2023).

The adoption of a new culture within the organization has been equally critical. Regular mandatory security training and periodic "security syncs" have effectively ingrained compliance in the organization's culture through a top-down approach, as explained by (Rindell et al., 2021). As (Drissi et al., 2025) note, the continuous development of cloud technology increases compliance risks, emphasizing the need for Agile teams to include the ongoing risk assessment practices of ISO 27001. Such examples highlight the importance of flexible frameworks customized for specific organizational needs. The secret to successful integration is to ensure that ISO 27001 technical controls are aligned with Agile's human-centered approaches. To provide a concrete example, BankCorp uses AI to decentralize control, whereas TechSME employs gamification to encourage staff engagement. Organizations such as BankCorp show that combining Agile and ISO standards. However, it is possible to require thoughtful process redesign, including developing an ISO-compliant Definition of Done.

2.4 Integrating Security into Agile Frameworks: Strategies for Socio-Technical Alignment

The combination of Agile methodologies and ISO 27001 compliance requires deliberate methods that align technical controls with human and organizational aspects. Based on the sociotechnical systems theory, we examine tangible solutions (from automated tools to organizational culture transformations) that help firms embed security into Agile practices without losing the pace of change. We will compare the implementation of these strategies in a TechSME and a BankCorp (MNE), with an emphasis on how the differences in scale of organization, funding, and sectoral standards affect their success.

2.4.1 Security-Focused User Stories: Bridging Functional and Non-Functional Requirements

The Agile methodology's user story approach, which is typically used to deliver features, can also be adapted to include security requirements. Reframing ISO 27001 controls as user stories, such as "As a user, I need encrypted data storage to meet ISO Control A.10.1.1," enables teams to prioritize security requirements as they would features (Moyon et al., 2020). TechSME's Approach: TechSMEs had difficulties with traceability due to a lack of tool support to include security stories in their sprint planning. In

an interview, a developer stated, “We log security issues in Jira, but manually linking them to ISO clauses is cumbersome” (Interview P6). BankCorp’s Solution: BankCorp overcame this challenge by integrating Confluence with Jira to automatically associate user stories with ISO controls, making traceability during audits easier. This improvement resulted in a 30% reduction in the time required for audit preparation. This approach follows Lean Security principles, reducing paperwork and monitoring compliance (Assal and Chiasson, 2019).

2.4.2 Automation and Tooling: Scaling Compliance in CI/CD Pipelines

The application of automation allows for the effective integration of Agile methodologies with the strict standards of ISO 27001. Organizations leverage DevSecOps to incorporate security checks in CI/CD workflows, while SMBs opt for cost-effective security tools. BankCorp’s Automation: By leveraging integrated SAST and DAST solutions such as Check Marx and OWASP ZAP, vulnerability scans were automated, and 80% of issues were detected and mitigated before deployment (Interview P9). (McCoy, 2025) study demonstrates real-life SDLC security integration, which justifies BankCorp’s use of SAST/DAST tools that comply with ISO 27001’s Annex A.14 (Appendix C, Table C.1) requirements.

The application of AI in risk assessment prioritized key controls that align with sociotechnical systems that emphasize adaptive governance, as described by (Asprion et al., 2023). (Prates and Pereira, 2025) state that ISO 27001-compliant DevSecOps tools automate more than 40% of security checks, like BankCorp’s integrated SAST/DAST pipelines in their CI/CD workflow. TechSME’s Constraints: Open-source tools like Trivy and Wazuh were used because of budgetary limitations. While functional for routine scanning, developers identified areas where tools lacked accuracy. As reported by (Interview P3), automated tools often provided by organizations tend to ignore deep-rooted security problems. (Adams, 2019) states that many organizations do not understand CI/CD pipelines, and they emphasize that there should be careful coordination between Agile development cycles and the detailed processes of ISO 27001 to avoid compliance issues in automated systems. Automation emphasizes combining technical solutions and human processes so tools and workflows can work together (Baxter and Sommerville, 2011).

2.4.3 Cultural Adaptation: Training and Security Champions

Cultural resistance remains a barrier, particularly in SMEs where developers perceive compliance as bureaucratic. Mitigation requires role-based interventions and education. Security Champions: TechSME designated part-time "Security Champions" who earned gamified badges for completing ISO modules. This fostered grassroots ownership, increasing compliance adherence by 40%. Enterprise Training: BankCorp institutionalized compliance through mandatory workshops and monthly "security syncs," reducing ticket backlogs by 50% as developers proactively sought clarifications (Interview P7). These practices reflect sociotechnical systems theory, where cultural shifts (human) and governance structures (technical) are interdependent (Baxter and Sommerville, 2011).

2.4.4 Hybrid Models: Balancing Legacy Systems and Agile Innovation

Organizations with legacy infrastructure often adopt hybrid Agile-waterfall models to meet ISO 27001's stability requirements. (Shetty, 2023) proposes an ISO controls-based framework for SMEs, underscoring the viability of hybrid Agile-waterfall models to manage legacy system compliance. BankCorp's Hybrid Framework: Segregated legacy systems (managed via waterfall) from Agile-driven APIs, using "ISO Sync" meetings to align risk assessments across teams. This hybrid approach reduced remediation time by 50%. TechSME's Iterative Compliance: Conducted mini-audits during sprint retrospectives, incrementally documenting risks, a Lean approach minimizing upfront bureaucracy (Moyon et al., 2020).

2.4.5 Theoretical and Practical Synthesis

The strategies above underscore the necessity of context-specific frameworks: SMEs: Lean, iterative processes (e.g., gamification, open-source tools) align with resource constraints. Enterprises: Automation and centralized governance ensure scalability and audit readiness. By anchoring these strategies in sociotechnical systems theory, organizations can navigate the agility-compliance dichotomy, transforming ISO 27001 from a constraint into an enabler of secure innovation. (Toomey, 2021) analyzes Agile-ERP integration risks, paralleling BankCorp's hybrid governance model to balance ISO 27001 compliance with multi-phase project delivery.

2.5 Case Studies and Empirical Evidence: Synthesizing Contextual Insights

This section synthesizes empirical evidence from the anonymized case studies (TechSME and BankCorp) and aligns them with broader findings from the literature, illustrating how organizational context shapes Agile-ISO 27001 integration. By contrasting SME and enterprise approaches across industries, the analysis underscores the sociotechnical interplay of culture, tools, and processes in balancing agility with compliance. As shown in Table 2.1, SMES and large enterprises adopt markedly different ISO–Agile integration strategies.

2.5.1 Financial Sector: Balancing Rigor and Speed

BankCorp (MNE):

- Challenge: As a multinational financial institution, BankCorp faced delays in critical updates (e.g., encryption upgrades) due to ISO 27001's mandatory risk assessments. These clashed with Agile's sprint timelines, creating friction between developers and auditors.
- Solution: Implemented hybrid Agile-waterfall models for legacy systems, coupled with automated CI/CD pipelines for new APIs. SAST/DAST tools reduced manual security checks by 40%, while AI-driven risk scoring prioritized high-impact controls.
- Outcome: Achieved compliance without sacrificing agility, reducing audit penalties by 70% (Interview P12).

(Smith et al., 2022), observed similar hybrid models in financial firms, where segregated workflows for legacy and Agile systems reduced remediation time by 50%. Automation of compliance evidence generation (e.g. Confluence templates) further streamlined audits, aligning with sociotechnical systems theory's emphasis on adaptive governance (Baxter and Sommerville, 2011).

2.5.2 Healthcare: Security Sprints and Proactive Compliance

Literature Example: A healthcare software provider (Moyon et al., 2020) embedded ISO 27001 controls into Agile workflows through security

sprints, dedicated iterations for risk assessments, and control implementation. For example, user stories like "As a clinician, I require HIPAA-compliant data storage (ISO A.10.1.2)" ensured alignment with regulatory requirements. TechSME (SME):

- Challenge: Limited resources prevented dedicated security sprints, leading to retroactive documentation.
- Solution: Adopted lightweight "mini-audits" during sprint retrospectives, incrementally aligning checklists with ISO 27001 clauses. Gamified "Security Champion" roles incentivized compliance ownership.
- Outcome: Reduced audit preparation time by 30% despite initial gaps in traceability (Interview P6).

Synthesis: While enterprises leverage structured security sprints, SMES like TechSME adopt iterative, low-cost adaptations. Both approaches reflect Lean Security principles, minimizing waste while addressing compliance (Assal and Chiasson, 2019).

2.5.3 Cross-Industry SME Strategies: Flexibility Over Formality

TechSME (IT Services SME):

- Tooling: Used open-source tools (Trivy, Wazuh) for vulnerability scanning, reducing costs by 60% but sacrificing precision (Interview P3).
- Cultural Shifts: Part-time security champions and gamification (e.g., badges) increased compliance adherence by 40%.

(Huhtinen, 2021) documented similar SME adaptations, where ISO 27001 documentation was simplified into "emoji checklists" for volunteer teams, achieving 90% compliance despite resource constraints. These findings align with sociotechnical systems theory's focus on human-centric solutions in resource-limited settings (Baxter and Sommerville, 2011). As noted by (Abid, 2025), SMES in sectors like banking and retail often adopt lightweight, iterative compliance strategies to balance ISO 27001 requirements with Agile workflows, leveraging industry-specific adaptations to mitigate resource constraints. (Nam, 2023) explores low-code platforms as enablers for SME agility, offering a pragmatic approach to balancing ISO 27001 compliance with rapid application development.

2.5.4 Enterprise Scale: Automation and Governance

BankCorp:

- Automation: Integrated SAST/DAST tools into CI/CD pipelines, auto-generating 70% of audit evidence.
- Cultural Governance: Mandatory security training and monthly "syncs" reduced developer-auditor friction, institutionalizing compliance as a shared responsibility (Interview P7).

Literature Parallel: (Tanneru, 2025) highlighted DevSecOps as a critical enabler for enterprises, noting that AI-driven tools reduced vulnerability detection-to-patching time by 50% in banking sectors. Similarly, (Culot et al., 2021) emphasized centralized governance in multinational firms to align Agile teams with ISO 27001's procedural demands.

2.5.5 Theoretical Synthesis: Sociotechnical Alignment in Practice

The case studies and literature collectively demonstrate that successful integration hinges on SMES prioritizing Lean, iterative processes (e.g., TechSMES mini-audits), while enterprises invest in automation and governance (e.g., BankCorp's AI tools). Cultural-Process Symbiosis: Tools and workflows must align with team culture, whether through gamification (TechSME) or mandatory training (BankCorp). Hybrid Frameworks: Segregating legacy and Agile systems (BankCorp) or blending compliance into the Definition of Done (DoD) (TechSME) balances stability with innovation. These insights reinforce sociotechnical systems theory, where technical controls (e.g., automation) and human factors (e.g., security champions) are interdependent (Baxter and Sommerville, 2011).

2.6 Theoretical Perspectives: Bridging Agile and Compliance Through Sociotechnical Frameworks

The integration of Agile methodologies with ISO 27001 compliance is not merely a technical challenge but a sociotechnical endeavor requiring alignment of human, organizational, and technological factors. This section expands on the theoretical underpinnings introduced earlier, synthesizing insights from sociotechnical systems theory, institutional theory, Lean

Security, and adaptive governance to explain how organizations navigate the agility-compliance dichotomy. These frameworks are contextualized through the case studies of TechSME (SME) and BankCorp (MNE), demonstrating their practical relevance.

2.6.1 Sociotechnical Systems Theory: Interdependence of People, Tools, and Processes

Sociotechnical systems theory posits that effective organizational performance arises from the harmonious interaction of social (human) and technical (technological, procedural) components (Baxter and Sommerville, 2011). In the context of Agile-ISO 27001 integration, key sociotechnical components include technical elements such as ISO 27001 controls (risk assessments, audit trails) and Agile's CI/CD pipelines, alongside social elements including team autonomy, a proactive security culture, and effective collaboration between developers and auditors. BankCorp automated compliance checks (technical) but also embedded auditors into sprint reviews (social), reducing friction between teams. TechSME used gamification (social) to incentivize compliance alongside open-source tools (technical), fostering grassroots engagement. This theory explains why purely technical solutions (e.g., Static Application Security Testing (SAST) tools) fail without cultural buy-in, and vice versa. For instance, BankCorp's AI-driven risk scoring tools (technical) succeeded only after mandatory training (social) aligned teams with compliance goals.

2.6.2 Institutional Theory: Compliance as a Strategic Imperative in Regulated Industries

Institutional theory states that external factors like regulations and industry standards significantly shape organizational behavior (Dumont et al., 2021). For instance, organizations like BankCorp use ISO 27001 not only for security benefits but also to satisfy stakeholder needs and comply with regulations such as GDPR and HIPAA. According to (Iryna and Anastasiia, 2024), adopting ISO 27001 is a progressive way of addressing global risks, which aligns with BankCorp's focus on auditability rather than speed. As illustrated in the case study, BankCorp's combination of Agile and waterfall methods and centralized governance reflects the desire for stability and audibility common in the finance industry. On the other hand, smaller startups in the technology sector prefer Lean processes, which reflects their lighter regulatory burden and preference for practical controls over rigid

compliance. According to research by (Culot et al., 2021), the rigidity of ISO 27001 is due to its critical nature in the field of sectors, where regulatory breaches can have severe legal and reputational implications. This perspective aligns with BankCorp's emphasis on strong security practices rather than timely sprint completion.

2.6.3 Lean Security: Minimizing Waste, Maximizing Value

By applying the core Lean principles, Lean Security aims to eliminate administrative burdens without compromising the reliability of security controls, as noted by (Assal and Chiasson, 2019). This is particularly important for SMEs like TechSMEs because they need to be careful when allocating resources and focus on efficiency. TechSME's strategy included incrementally documenting risks during sprints, which allowed them to avoid upfront bureaucratic barriers and adhere closely to Lean's "just-in-time" principle. In contrast, BankCorp reduced manual documentation by a staggering 70% by adopting automated evidence generation, highlighting Lean's emphasis on efficiency. Also, (Moyon et al., 2020) note that a "security sprint" approach has replaced extensive paperwork with focused risk evaluations in healthcare.

2.6.4 DevSecOps and Adaptive Governance: Scaling Compliance in Agile Environments

DevSecOps is an extension of the DevOps methodology, incorporating security measures into continuous integration and deployment processes. Adaptive governance also allows for a more flexible and responsive compliance strategy that aligns with changing project needs (Asprion et al., 2023; Fitzgerald and Stol, 2017). BankCorp is a good example of how DevSecOps can be successfully implemented by incorporating SAST and DAST tools into their CI/CD pipelines for immediate vulnerability detection. AI allowed real-time changes to priority controls, facilitating adaptive governance by allocating resources appropriately. In their extensive research, (Brezav s cek and Baggia, 2025) present several cybersecurity maturity models and emphasize the necessity of ongoing verification to align Agile's ever-changing environment with ISO 27001 standards. TechSMEs adopted an agile approach to governance by changing their compliance strategy through sprint retrospectives. These approaches are consistent with the sociotechnical systems theory, which focuses on balancing the automation of processes (the technical) with human oversight (the social).

Consider BankCorp's (technical) AI applications, which demonstrated significant reliability and effectiveness

2.6.5 Synthesis: Toward a Contextual Theoretical Framework

According to these theories, the Agile-ISO 27001 integration varies for each organization due to its complexity. For example, multinational corporations, like BankCorp, can be compelled by institutional pressure and a readily available amount of resources towards adopting DevSecOps and centralized governance. In small and medium enterprises, like TechSME, priority is likely to be given to Lean Security and sociotechnical alignment, as they seek affordable alternatives that suit their culture. Organizations must tailor their strategies for practice according to the size, industry, and risk profile. Theoretical frameworks must guide rather than dictate the rules of integration so that there can be flexible adjustments, such as how TechSME may use gamification compared to BankCorp's emphasis on automation.

2.7 Challenges and Considerations: Navigating the Agile-ISO 27001 Integration Landscape

The amalgamation of Agile methodologies and ISO 27001 compliance frequently leads to many challenges because of different mindsets, processes, and environments. We will review the significant challenges reported in previous studies and case reports, classify them based on theoretical models, and suggest strategies for their resolution.

2.7.1 Cultural Resistance and Misalignment

Challenge: Agile developers thrive on freedom, speed, and low bureaucracy, but ISO 27001 demands a more structured process with a governance and documentation approach. This cultural clash often leads developers to oppose compliance efforts that they see as stumbling blocks.

Case Study Example: At TechSME, the programmers initially sidestepped official risk assessments to adhere to their sprint deadlines, eventually leading to them suffering in audits (Interview P6). Similarly, BankCorp resisted until they included auditors within their sprint reviews.

Theoretical Lens: Sociotechnical systems theory explains this as a misalignment between human factors (team autonomy) and technical requirements (documentation) (Baxter and Sommerville, 2011).

Mitigation: TechSME's gamified roles fostered grassroots ownership, increasing compliance adherence by 40%. Auditor. BankCorp's "security syncs" bridged cultural gaps, reducing ticket backlogs by 50% (Interview P7).

2.7.2 Documentation Overhead

Challenge: Agile's emphasis on working software over comprehensive documentation conflicts with ISO 27001's rigorous audit trails.

Case Study Example: TechSME's lightweight checklists reduced planning time by 30% but lacked traceability to ISO clauses. BankCorp automated Confluence templates to link user stories with controls, cutting audit prep time by 70%.

Literature Support: (Moyon et al., 2020) note that SMEs often adopt "iterative compliance" to balance agility and documentation. Tools like GitLab CI/CD and Drata auto-populate ISO documentation, minimizing manual effort. Incremental updates during sprint retrospectives (TechSME) or AI-driven summaries of security reports (BankCorp). (Nurmi, 2024) advocates for project management frameworks to streamline ISO 27001 documentation, a strategy BankCorp operationalized through AI-driven Confluence templates.

2.7.3 Resource Constraints in SMEs

Challenge: Limited budgets and personnel restrict SMEs' ability to implement enterprise-grade security controls.

Case Study Example: TechSME relied on open-source tools (Trivy, Wazuh) but faced precision gaps compared to BankCorp's SAST/DAST tools (Interview P3).

Literature Support: (Culot et al., 2021) highlight that ISO 27001's perceived rigidity stems from SMEs' resource limitations. (Talib et al., 2012) demonstrate ISO 27001's pedagogical value, suggesting simplified frameworks like TechSME's 'emoji checklists' to educate resource-constrained teams. (Sang, 2023) underscores the challenges faced by SMEs in resource-limited settings, proposing tailored cybersecurity assessment models that align with TechSME's adoption of open-source tools like Wazuh to offset budget constraints.

Mitigation: Simplified frameworks (e.g., emoji checklists for volunteers) and partnerships with shared-service audit firms (Huhtinen, 2021). Focus on high-impact controls using AI-driven risk scoring (Asprion et al., 2023).

2.7.4 Evolving Threat Landscape

Rapidly changing cyber threats require continuous updates to security controls, conflicting with Agile's focus on speed.

Case Study Example: BankCorp delayed an encryption update for risk assessment, exposing vulnerabilities (Smith et al., 2022). (Tanneru, 2025) Advocates are integrating Security Vulnerability Management (SVM) into CI/CD pipelines for real-time monitoring.

Automated Scanning: Embed SAST/DAST tools into CI/CD (BankCorp reduced vulnerabilities by 80%). (Axon et al., 2022) highlight emerging vulnerabilities in Industrial IoT systems, underscoring the urgency of integrating threat modeling into Agile sprint planning to address ISO 27001's Annex A controls (Appendix C) proactively. Conduct threat modeling during sprint planning (Thool and Brown, 2024).

2.7.5 Governance vs. Autonomy

Challenge: ISO 27001's centralized governance clashes with Agile's decentralized decision-making. (Lopes et al., 2019) demonstrate ISO 27001's synergies with GDPR, underscoring the importance of cross-functional collaboration to navigate overlapping compliance mandates in Agile environments.

Case Study Example: BankCorp's mandatory security gates conflicted with sprint timelines until hybrid models segregated legacy and Agile systems. Institutional theory explains enterprises' need for stability in regulated sectors (Dumont et al., 2021).

Mitigation: Hybrid Models like waterfall for legacy systems and agile for APIs, with "ISO Sync" meetings. Adaptive Governance, like AI-driven tools, prioritizes controls dynamically (BankCorp) or iterative compliance (TechSME).

2.7.6 Tooling and Automation Costs

Challenge: High costs of automation tools create barriers for SMEs.

Case Study Example: TechSME's open-source tools saved 60% costs but lacked precision (Interview P3).

Literature Support: (Fitzgerald and Stol, 2017) note that automation Return on Investment (ROI) depends on organizational scale.

Mitigation: Start with low-cost tools (e.g., Trivy) and scale as compliance matures. Use Jira plugins for SMEs or enterprise-grade platforms like ServiceNow. The challenges underscore the necessity of context-specific

strategies. For SMEs, lean adaptations, gamification, and partnerships. For enterprises, automation, hybrid models, and centralized governance. By aligning solutions with sociotechnical systems theory, balancing technical controls and human factors, organizations can transform ISO 27001 from a compliance burden into a strategic enabler of secure innovation.

2.8 Future Directions: Emerging Trends and Research Opportunities

The integration of Agile methodologies with ISO 27001 compliance remains a dynamic field, shaped by technological advancements, evolving threats, and shifting organizational needs. Building on the challenges identified in, this section outlines future research directions and practical innovations, contextualized through the lens of sociotechnical systems theory and aligned with empirical insights from TechSME (SME) and BankCorp (MNE).

2.8.1 AI and Machine Learning in Compliance Automation

Trend: AI-driven tools are increasingly used to prioritize risks, auto-generate documentation, and streamline audits.

Case Study Insights: BankCorp leveraged AI risk scoring to dynamically allocate resources to high-impact controls, reducing compliance debt by 30%. (Ceko, 2024) identifies global trends in ISO adoption, advocating for AI-driven tools to reduce documentation overhead while maintaining audit readiness, a strategy successfully implemented by BankCorp. TechSME explored Large Language Models (LLMs) to summarize security reports, though limited budgets hindered implementation (Interview P3).

Literature Alignment: (Tanneru, 2025) advocates for AI-enhanced Security Vulnerability Management (SVM) in CI/CD pipelines, while (Asprion et al., 2023) propose "CaC" frameworks to codify ISO rules.

Future Research: How can SMEs adopt cost-effective AI tools without sacrificing precision? Can generative AI (e.g., LLMs) reduce documentation burdens while maintaining audit rigor?

2.8.2 Sector-Specific Frameworks for Regulated Industries

Trend: Healthcare, government, and finance require tailored Agile-ISO 27001 frameworks to address unique regulatory demands (e.g., HIPAA,

GDPR). (O'g'li, 2025) illustrates ISO's adaptability beyond IT, such as hydrogen transport regulations, suggesting future research into sector-specific Agile compliance frameworks for healthcare or energy. (Gaggero et al., 2024) Propose a secure-by-design framework for energy communities under IEC 62443, suggesting parallels for ISO 27001 integration in Agile-driven critical infrastructure projects.

Case Study Insights: BankCorp's hybrid model for legacy systems could inform healthcare adaptations, where stability is critical. TechSME's iterative compliance aligns with non-profits needing low-cost solutions (Huhtinen, 2021). Literature Alignment: (Culot et al., 2021) emphasize ISO 27001's flexibility but note that sector-specific controls are understudied.

Future Research: What hybrid models best balance Agile and ISO 27001 in sectors like healthcare? How can "security sprints" (Moyon et al., 2020) be standardized across industries?

2.8.3 SME-Centric Solutions: Bridging Resource Gaps

Trend: SMEs need lightweight, scalable tools to overcome budget and expertise limitations.

Case Study Insights: TechSME's gamification and open-source tools (Trivy, Wazuh) reduced costs by 60% but highlighted precision trade-offs. (Huhtinen, 2021) proposed "emoji checklists" for volunteer-driven compliance in SMEs.

Literature Alignment: Lean Security principles (Assal and Chiasson, 2019) advocate minimizing waste, yet SME tooling remains underexplored.

Future Research: Can collaborative platforms (e.g., Jira plugins) democratize enterprise-grade compliance for SMEs? How do cultural interventions (e.g., gamification) scale across diverse SME contexts?

2.8.4 Longitudinal and Behavioral Studies

Trend: The long-term evolution of Agile-ISO 27001 strategies amid emerging threats (e.g., AI-driven cyberattacks) is poorly understood.

Case Study Insights: BankCorp's AI tools require continuous updates to address novel vulnerabilities. TechSME's iterative compliance may struggle with escalating regulatory complexity. Literature Alignment: (Rindell et al., 2021) Call for studies tracking security practices across Agile maturity levels.

Future Research: How do integration strategies evolve over a 5–10 year horizon? What behavioral factors (e.g., developer mindset shifts) sustain compliance in Agile teams?

2.8.5 Zero Trust and Agile Integration

(Kuusisto, 2022) links Agile-ISO integration to resilience in Volatility, Uncertainty, Complexity and Ambiguity (VUCA) environments, advocating for Zero Trust principles to mitigate evolving cyber threats without stifling developer autonomy. Zero Trust Architecture (ZTA), which assumes no implicit trust in systems, complements ISO 27001 but introduces new workflow complexities.

Case Study Insights: BankCorp piloted ZTA for API access controls, requiring Agile teams to adopt micro-segmentation. TechSME lacked resources for ZTA but used multi-factor authentication (ISO A.9.4.2 (Appendix C)) as a precursor.

Literature Alignment: (Tokerud et al., 2023) propose Zero Trust maturity models aligned with sociotechnical systems.

Future Research: How can Zero Trust principles be incrementally adopted in Agile workflows? Does ZTA enhance or hinder developer autonomy in SMEs vs. enterprises?

2.8.6 Cultural and Psychological Dimensions

Employee resistance and organizational inertia remain underaddressed in technical frameworks.

Case Study Insights: TechSME's "Security Champions" relied on intrinsic motivation (badges), while BankCorp used extrinsic incentives (mandatory training). (Munir, 2024) links ISO 27001 success to leadership buy-in and psychological safety. Sociotechnical systems theory underscores the need to align tools with cultural norms (Baxter and Sommerville, 2011).

Future Research: What incentive structures (e.g., gamification vs. penalties) most effectively drive compliance? How does psychological safety influence security accountability in Agile teams? Future work must bridge the gaps between theoretical frameworks and practical realities. For enterprises, explore AI-driven governance and Zero Trust integration in hybrid models. For SMEs, develop lean, culturally adaptive tools that

scale with growth. Standardize sector-specific frameworks while preserving Agile-ISO 27001 flexibility. By anchoring research in sociotechnical systems theory, scholars and practitioners can transform ISO 27001 from a compliance checkpoint into a catalyst for secure innovation.

3

Methodology

This chapter presents the research design used to explore Agile–ISO 27001 integration. A qualitative multiple case-study approach was chosen to gain in-depth, context-rich insights into how different organizations manage the agility–security trade-off. As (Yin, 2018) notes, case studies are particularly effective for investigating contemporary phenomena in their real-life contexts. This design contrasts with a purely quantitative survey or single-case approach. A survey could have measured trends across many organizations, but it would have lacked the nuance needed to understand how and why specific strategies work. A single case would limit generalizability. The multiple-case approach enables cross-context comparisons (TechSME vs. BankCorp) while respecting each setting's uniqueness.

Each case study involved semi-structured interviews, document analysis, and observation. Semi-structured interviews with 12 practitioners, including developers, security officers, and managers, provided detailed insights into organizational practices and challenges. Interviewees were purposefully sampled to cover diverse roles and experience levels. Document analysis (e.g., project records, compliance artifacts) and meeting observations helped triangulate the interview data. Data collection was guided by sociotechnical systems theory and Lean Security principles, which helped identify relevant social and technical factors. For example, in each case, we asked about team culture, communication, and tooling (aligning with the sociotechnical emphasis on people–technology alignment).

While alternative methods were considered, a quantitative approach involving statistical analysis of compliance metrics was ultimately rejected

due to challenges in defining standardized measures for “agility” or “security maturity,” and because the research aim was exploratory in nature. Likewise, a pure design-science approach (building a prescriptive tool or framework from scratch) was deemed premature without rich field data. The chosen qualitative case-study method allowed emergent themes to be grounded in practice. To ensure rigor, the study employed techniques such as participant validation (sharing findings with interviewees), chain-of-evidence documentation, and clear coding procedures, enhancing credibility and dependability.

Finally, the methodology is justified by the nature of the research question. Understanding the trade-offs and integration strategies between Agile and ISO 27001 requires capturing practical experiences and organizational context. This approach yields actionable knowledge (e.g., specific automations, cultural interventions) that purely theoretical or survey methods would likely miss.

3.1 Research Design

This study adopts a qualitative case study design to allow for an in-depth, contextualized understanding of ISO 27001 integration in Agile settings. A comparative approach was used to contrast practices between an SME and an MNE. This study aims to better understand the relationship between Agile flexibility and the formal controls specified in ISO 27001. The use of case studies was driven by their usefulness in exploring complex, context-bound problems in practice-based settings (Creswell and Poth, 2016). Two organizations, TechSME, a small-to-medium software development firm, and BankCorp, a multinational financial institution, serve as focal examples. These organizations were selected to reflect varied operating conditions:

- Industry diversity: TechSME operates in the IT services sector, characterized by rapid innovation cycles, whereas BankCorp functions within the heavily regulated financial industry, where compliance is non-negotiable.
- Organizational scale: TechSME exemplifies resource-constrained small and medium-sized enterprises (SMEs), while BankCorp represents large enterprises with dedicated compliance infrastructures.

This dual-case framework enables a nuanced exploration of how organizational size, industry norms, and risk profiles shape Agile-ISO 27001 integration. Pseudonyms and generalized identifiers (e.g., 'Northern European IT services firm') preserve confidentiality while maintaining analytical relevance. While quantitative surveys could quantify compliance delays, qualitative interviews and observations were chosen to capture nuanced sociotechnical dynamics and contextual adaptations.

- Industry diversity: TechSME is a specialist in IT services, an industry characterized by rapid adoption of new technologies, as opposed to BankCorp, which is in the highly regulated financial industry, where compliance standards are inflexible.

- Organizational scale: TechSME embodies operations unique to small-to-medium-sized enterprises limited by resources, in contrast to BankCorp's larger-scale entities that depend on sophisticated compliance infrastructures.

Using these two cases, we can get a clear picture of how organizational size, industry standards, and risk factors affect the integration of Agile methodologies with ISO 27001.

By using pseudonyms and general identifiers like 'Northern European IT services firm,' we were able to maintain identity protection while retaining the analytical value of the research. Even though surveys could have measured compliance delays, we chose individual interviews and field observations to reveal the subtle interactions between people and technology.

3.2 Case Selection Criteria

Our choice of cases was based on some criteria to make our analysis prosperous and inclusive:

1. Incorporation of Agile practices with ISO 27001 implementation: Organizations should be adopting Agile practices in their ISO 27001 security efforts. Our selection criteria included organizations that were implementing both Agile methods and ISO 27001 certification efforts. This enables us to see the real challenges of combining these two approaches.

2. Representation of Industries: To see how regulatory practices differ by industry, we added sectors such as IT services and finance, looking at the particular security priorities that clash with agility goals.

Our future research may also include healthcare, given the unique protection standards required by HIPAA for personal health information, which are different from those required for ordinary operational data (Khadka et al., 2022).

3. Organization size: We sampled organizations from startups to large-scale to assess how resource availability and organizational complexity influence their strategies for compliance with regulations. In large organizations, automated tools are used to automate compliance processes, unlike the more flexible and cost-effective approaches that are favored by SMEs.

4. Cases of security breaches or non-compliance:« Our research focused on cases where Agile practices were altered due to security breaches or audit failures, which gave us a glimpse of real-world conflicts.

By choosing this approach, our study is capable of collecting both general patterns and specific regional details, providing valuable insights into various organizational contexts. To clearly define the scope of analysis, explicit case boundaries and contextual factors for each selected organization are discussed below.

3.3 Case Boundaries and Operational context

The temporal scope refers to the overall duration of ISO 27001 and Agile integration initiatives studied in each organization. For TechSME, the initiative examined covers approximately 12 months from the inception of ISO 27001 integration efforts. For BankCorp, this period spans approximately 18 months due to the complexity and scale involved in their integration approach.

3.3.1 TechSME

TechSME is a Stockholm-headquartered fintech organization operating primarily in the Nordic region, with additional activities in several other countries. Employing approximately 200 people, the company's main business areas include software development, consumer WiFi solutions, router technologies, and cloud management services. Given the sensitive nature of financial transactions and personal data managed by TechSME, the

firm operates under considerable compliance pressures, making integrating ISO 27001 standards into Agile processes particularly relevant and challenging.

3.3.2 BankCorp

BankCorp is a multinational financial institution with a significant presence in the Nordic region. The organization maintains a complex structure with multiple departments adhering to stringent regulatory requirements. This case study centers on a cross-functional team within BankCorp's IT division that aligned ISO 27001 standards with existing Agile methodologies. The study period covers 18 months, encompassing this integration's planning, implementation, and evaluation phases. Data were gathered through in-depth interviews, document analysis, and direct observations of Agile ceremonies and security audits.

By delineating these cases, the study aims to explore the nuanced challenges and strategies associated with harmonizing ISO 27001 standards within Agile environments across different organizational scales and industries. The following section details the methods employed for data collection, ensuring the comprehensive gathering of relevant empirical data.

3.4 Data Collection Methods

The best approach to answering our research questions was to use a combination of three related data collection methods.

3.4.1 Document Analysis

By carefully analyzing organizational materials, we aimed to better understand compliance practices and the adoption of Agile methodologies. The reviewed documents included:

- Internal Policies: It adopted security guidelines, Agile methodologies, and risk management systems.
- Audit Reports: We examined ISO 27001 certification audit reports and any corrective action plans that were implemented after those audits.
- Project Artifacts: We also reviewed sprint backlogs, user stories, and the records from the retrospective meeting.

TechSME's lean risk assessment templates demonstrated their commitment to reconciling Agile's preferred light documentation with the formal procedures required by ISO 27001. In contrast, BankCorp's automated audit trails in Confluence showed a commitment to compliance throughout the organization. The analysis of these documents shed light on standard practices, but obstacles such as gaps in documentation necessitated cross-referencing with additional materials. (Duarte, 2020) identifies obstacles to implementing Agile in highly regulated environments, similar to the TechSME's struggle to incorporate ISO 27001 documentation into their sprint retrospectives.

3.4.2 Semi-Structured Interviews

Interviews were conducted with 12 practitioners across roles critical to Agile-security integration, including Agile coaches, software developers, compliance officers, and security champions. Participants were purposively sampled from TechSME and BankCorp to capture diverse perspectives. The interview protocol explored:

- Perceived tensions between Agile flexibility and compliance requirements.
- Strategies for embedding security controls into iterative workflows.
- Organizational adaptations to mitigate cultural or procedural resistance.

Interviews, lasting 30–45 minutes, were transcribed verbatim and analyzed thematically (Braun and Clarke, 2006). For instance, a BankCorp compliance officer emphasized the non-negotiable nature of security gates despite Agile deadlines: "The cost of non-compliance outweighs delays" (Interview P11). To mitigate self-reporting biases, findings were juxtaposed with observational and documentary data. Participants were selected based on their direct involvement in Agile-ISO integration, including developers, compliance officers, and roles bridging both domains.

The complete interview guide, showing the question wording, prompts, and consent details, is provided in Appendix A and Appendix B for transparency and reproducibility.

Primary data collection, including semi-structured interviews, document analysis, and direct observations, was conducted intensively over a

period of approximately three months for each case. This allowed comprehensive, though time-bound, insights into ongoing integration processes at TechSME and BankCorp.

3.4.3 Direct Observations

Field observations at TechSME and BankCorp contextualized the interview and documentary findings. Over a two-week period, Agile ceremonies, including sprint planning sessions, daily stand-ups, and security retrospectives, were observed. Notable discrepancies emerged between formal policies and enacted practices. For example, while BankCorp's documentation emphasized automated compliance checks, developers occasionally bypassed security gates under tight deadlines. Detailed field notes were maintained, with sensitive information anonymized to adhere to ethical guidelines

3.5 Data Analysis Strategy

Thematic analysis, as outlined by (Braun and Clarke, 2006), was used to determine recurring themes across several data sources. The analysis concentrated on four aspects

1. Security-Agility Trade-Offs: The agile mindset, which promotes iterative development and minimal documentation (Beck et al., 2001), runs counter to the stringent requirements of ISO 27001, particularly in the areas of detailed risk analysis (Clause 8 (Appendix D, Table D.1)) and properly documented controls (Clause 7 (Appendix D, Table D.1)). For example, TechSME developers tended to prioritize sprint deliverables over keeping audit trails, so they had to backtrack and document afterwards.

2. Adaptation Patterns: Organizations that managed to balance agility and compliance would typically employ strategies like building security into user stories or automating evidence creation. For instance, BankCorp's implementation of SAST/DAST tools within their CI/CD pipelines cut down the manual effort by 40%, illustrating how larger companies can scale this.

3. Current Challenges: There has been one common challenge, which has been cultural resistance, especially within SMEs, as developers view compliance as just more bureaucratic red tape. TechSME

tackled this challenge by having gamified "Security Champion" roles, which helped create a shared responsibility culture.

4. Best Practices: Suggestions included proactive governance measures, such as regular internal audits, and AI-driven tools for real-time compliance notifications (Folorunso et al., 2024).

Cross-case comparison reflected industry-specific variation. For example, TechSME's inclination towards open-source tools like Wazuh contrasts with BankCorp's investment in enterprise-level platforms like ServiceNow. Table 3.1 summarizes the primary methodological dilemmas we encountered and the solutions we adopted to address them.

Table 3.1: Challenges vs. Solutions in Balancing Agile and ISO 27001

Challenge	Solution	Participant(s)	Tools/Techniques
Developer resistance to ISO docs	Gamification (Security Champions, badges)	P1, P5, P9, P10	Jira gamification plugins, internal LMS
Bureaucratic ISO documentation	Automated evidence generation	P2, P4, P7, P8	Confluence, GitLab CI/CD, Drata
Auditors unfamiliar with Agile	Educate auditors via sprint reviews/dashboards	P1, P2, P7, P8, P11	Jira dashboards, Miro boards
Legacy systems vs. Agile speed	Hybrid waterfall–Agile models	P7, P11	ServiceNow, LogicGate
Resource constraints (SMEs/NPOs)	Open-source tools + "lite" frameworks	P5, P10	Wazuh, OpenVAS, Bitwarden
Redundant GDPR/ISO controls	Unified compliance matrix	P3, P12	Spreadsheets, Lucidchart
Lack of security skills in teams	Partnerships for upskilling (Cybrary, peer mentoring)	P8, P10	Burp Suite training, peer-led workshops

3.6 Reliability and Validity

Multiple validation techniques were applied during data collection and analysis to ensure the credibility and trustworthiness of the study. Triangulation of data sources, including semi-structured interviews, internal documentation, and participant observations, helped establish convergent validity. Member checking was employed by sharing preliminary findings with select participants for feedback and confirmation, which enhanced accuracy and interpretive reliability. Phenomenological bracketing was used during the coding process to reduce the influence of researcher

bias. Reflexive memos and peer debriefing were also integrated to foster transparency in the interpretive process. These strategies collectively enhanced the study's methodological rigor and supported the validity of its conclusions.

3.7 Ethical Considerations

The study adhered to GDPR-compliant practices, ensuring that participant identities remained confidential. Informed consent was obtained from all interviewees. Data were anonymized, and sensitive documentation was handled according to institutional ethical protocols. All observations were conducted in settings where participants knew the research purpose.

3.8 Delimitations

This study is bound by explicit parameters to ensure methodological precision and analytical depth. These parameters reflect epistemological choices made to balance theoretical exploration with practical feasibility, specifically when examining how ISO 27001 standards harmonize with Agile methodologies. This research focuses exclusively on two organizations:

- *TechSME*: A Nordic technology firm representing SMEs in the private sector.
- *BankCorp*: A Nordic multinational financial institution headquartered in Sweden, exemplifying large-scale institutional compliance frameworks.

This dual-case strategy enables comparative analysis across divergent organizational scales and industry contexts. However, it excludes public sector entities and NGOs whose operational dynamics may yield different compliance trajectories. Both organizations operate within Sweden's sociotechnical ecosystem, where national data protection laws intersect with EU-wide regulatory mandates (e.g., GDPR). Findings may not generalize to regions with different legal infrastructures.

Temporal Scope: The study examines early-stage ISO 27001 integration, analyzing implementation processes over a few months. Longitudinal outcomes such as post-certification sustainability are outside the scope.

Thematic Boundaries: The research is confined to the intersection of ISO 27001 and Agile software development methodologies. Other security

standards and project management frameworks are beyond the intended scope.

3.9 Note on AI-assisted Editing

This thesis includes limited use of AI tools in line with Stockholm University's academic integrity guidelines. AI tools were used in a limited and transparent way to support this thesis. ChatGPT was used for Overleaf LaTeX formatting assistance (e.g., table alignment, hyperlink styling) and for improving grammar and structure in selected sections. Grammarly was used during final proofreading to correct minor grammar and punctuation issues.

No AI tools were used to generate research content, analyze, or formulate conclusions. All academic work is the authors' own, and all AI-assisted outputs were critically reviewed before use.

The authors remain fully accountable for the content and conclusions presented in this thesis.

3.10 Summary

This chapter detailed the study's qualitative methodology, including case selection, data collection, analysis, and validation strategies. Ethical procedures and delimitations were clarified to ensure transparency. The next chapter presents the findings drawn from the comparative analysis of TechSME and BankCorp.

4

Results

This chapter combines data from semi-structured interviews, document analysis, and on-site observations from two anonymized organizations: TechSME, an IT-oriented SME, and BankCorp, a leading financial corporation. The findings show the difficulties organizations have in reconciling Agile practices with ISO 27001 requirements and how they try to address these differences.

4.1 Trade-Offs Between Agility and Compliance

The approaches that organizations took to balance the tension between Agile methodologies and ISO 27001 compliance were quite different. The TechSME approach emphasized the importance of prioritizing quick iterations over extensive documentation, with lightweight risk checklists saving teams 30% of their planning time. However, the absence of comprehensive documentation resulted in post-sprint audits, which were required to fill information gaps in audit processes. “A team member said, ’ISO documentation procedures hold us back on Agile timelines.’” We use checklists to remain productive, though auditors sometimes ask for additional information“ (Interview P6). On the other hand, strong compliance measures at BankCorp hampered critical software changes. A three-day delay was experienced while waiting for a formal risk assessment before upgrading the encryption library, which clashed with Agile sprint deadlines. A compliance officer said, ”We cannot circumvent security controls even if we miss deadlines.“ Non-compliance is more expensive than any delays that may

arise" (Interview P11). Legacy System Challenges: Legacy architectures mandated by waterfall governance had to be separately managed from Agile frameworks, and Agile teams had to attend mandatory "ISO Sync" meetings to remain aligned.

4.2 Strategies for Integration

4.2.1 Security-Focused User Stories

Both organizations embedded security requirements into Agile workflows, though with varying rigor. TechSME introduced user stories such as "As a user, I require multi-factor authentication (ISO Control A.9.4.2 (Appendix C, Table C.1))," which improved visibility but lacked traceability to ISO clauses (Appendix D). BankCorp, however, automated traceability via Jira-Confluence integration, linking user stories to controls and reducing audit prep time by 30%. Table 4.1 collates the principal recommendations derived from both case studies. (Mohd Zin et al., 2024) highlight the effectiveness of personal Scrum methodologies in educational settings, validating TechSME's use of gamified user stories to simplify ISO 27001 requirements.

Table 4.1: Key Recommendations

Strategy	Use Case	Tools/Techniques	Outcome
Embed ISO in Sprint 0	Prioritize controls early	Security user stories, CI/CD gates	<5 % velocity drop (P1), faster audits (P2)
Automate Compliance	Reduce manual overhead	SAST/DAST tools, SBOM generators	30–70 % faster audits (P3, P6)
Gamify Security	Boost team buy-in	Badges, leaderboards, "Security Champions"	15–40 % increase in compliance adherence
Hybrid Models	Legacy–Agile integration	Waterfall-Agile sync meetings, Jira plugins	50 % faster risk remediation (P7)
Compliance-as-Code	Scalable security	AI-driven risk scoring, Compliance-as-Code	30 % reduction in compliance debt (P3)
Shift-Left Security	Proactive risk mitigation	Threat modeling in sprint planning	2× faster incident response (P7, P12)
Unified Frameworks	Reduce redundancy	GDPR-ISO matrices, visual workflows	70 % fewer redundant controls (P12)
Educate Auditors	Align expectations	Live dashboards, sprint review invites	40 % faster audit readiness (P2)

4.2.2 Automation and Tooling

Table 4.2 provides a breakdown of automated controls and their impact on sprint velocity. BankCorp integrated automated security testing tools (e.g., integrating SAST/DAST into CI/CD pipelines, reducing manual effort by 40%. A DevSecOps engineer emphasized, "Automated scans catch 80% of vulnerabilities pre-deployment" (Interview P9). AI-driven risk scoring prioritized high-impact controls, reducing compliance debt by 30%. TechSME relied on open-source tools like Trivy due to budget constraints, with a developer noting, "Free tools help, but they lack enterprise-grade precision" (Interview P3). As detailed in Table 4.3, participants employed a diverse set of tools and techniques to embed security into Agile workflows.

Table 4.2: Tooling and Automation

Key Insight	Participant Evidence	Industry Impact
Automated Evidence Generation	"Confluence templates auto-populate ISO docs from Jira tickets." (P4)	
	"SBOMs auto-generate in CI/CD pipelines." (P6)	25–70% reduction in documentation time (P4, P6, P8).
AI-Driven Prioritization	"AI risk scoring focuses efforts on high-impact controls." (P3)	
	"Compliance-as-Code frameworks codify ISO rules." (P9)	30% reduction in compliance debt (P3).

Table 4.3: Tools & Techniques Across Participants

Tool/Technique	Purpose	ISO 27001 Clause	Participant
Jira Integrations	Traceability, compliance tagging	A.14 (Secure Development)	P1, P3, P7, P12
Confluence Templates	Auto-generated audit trails	A.12 (Operations Security)	P2, P4, P8
SAST/DAST Tools	Vulnerability scanning	A.14.2 (Secure Development)	P5, P6, P9
Miro Boards	Visual risk mapping	A.6 (Risk Assessment)	P11, P12
Open-Source SIEM	Budget-friendly monitoring	A.12.4 (Logging)	P10
AI-Driven Scoring	Prioritize high-risk tasks	A.6 (Risk Treatment)	P3, P11

4.2.3 Cultural Adaptation

Table 4.4 illustrates the cultural and behavioral changes that supported ISO–Agile integration. TechSME fostered shared ownership through a part-time "security champion" role, while BankCorp institutionalized compliance via mandatory training and monthly "security syncs." A BankCorp compliance officer observed, "Developers now tag us in Slack for quick clarifications, reducing formal ticket backlogs" (Interview P7).

Table 4.4: Cultural and Behavioral Shifts

Key Insight	Participant Evidence	Industry Impact
Gamification Drives Buy-In	"We launched 'Secure Innovator' badges—teams compete to hit 100% traceability." (P6)	
	"Volunteers earn 'Security Hero' badges for completing ISO modules." (P10)	Increased compliance adherence (15–40%) in startups (P9) and non-profits (P10).
Security as Shared Responsibility	"Compliance became a collaboration, not a constraint." (P12)	Reduced "us vs. auditors" mindset in banking (P7) and insurance (P11).

4.3 Challenges and Mitigation

Persistent challenges included documentation overhead, cultural resistance, and tooling costs. TechSME addressed documentation gaps by retroactively aligning checklists with ISO 27001 requirements, while BankCorp streamlined compliance reviews by pre-approving common changes. Hybrid Agile-waterfall models, automation, and AI-driven prioritization (Asprion et al., 2023). TechSME Iterative compliance, gamification, and partnerships with shared service audit firms (Huhtinen, 2021). Security champion remarked, "We treat ISO 27001 as a framework, not a straitjacket" (Interview P2), reflecting adaptive interpretations of compliance. As observed by (Sang, 2023), SMEs such as TechSME often rely on cost-effective solutions like open-source SIEM tools to navigate ISO 27001 compliance, despite trade-offs in precision and scalability. Table 4.5 maps resource limitations to the adaptive strategies adopted by each organization.

Table 4.5: Resource Constraints and Adaptations

Key Insight	Participant Evidence	Industry Impact
Open-Source Tools for SMEs	"Wazuh and OpenVAS replaced expensive SIEM tools." (P10) "Outsourced audits to shared-service firms." (P5)	60% cost reduction in audits (P5).
Simplified "Lite" Frameworks	"ISO controls became emoji checklists for volunteers." (P10) "Shift-left threat modeling saved 2 weeks of rework." (P9)	90% volunteer compliance (P10).

4.4 Success Factors

For SMEs like TechSME, success hinged on lightweight processes and cultural flexibility. In contrast, BankCorp leveraged automation and centralized governance. Automation at Scale: Reduced manual effort by 40%. These divergent approaches underscore the need for context-specific frameworks, as emphasized by a BankCorp executive: "Automation is costly upfront but saves millions in audit risks" (Interview P12). In Table 4.6, we compare how process elements from Agile and ISO 27001 were integrated in each case.

Table 4.6: Process Integration

Key Insight	Participant Evidence	Industry Impact
Compliance in the Definition of Done	"No feature ships without passing ISO A.14.2 checks." (P6) "Security subtasks are baked into user stories." (P5)	30% faster audit readiness (P2) and reduced rework (P12).
Hybrid Agile-Waterfall Models	"Legacy systems use waterfall; APIs use Agile. ISO Sync meetings keep both aligned." (P7)	50% faster risk remediation in banking (P7).

4.5 Summary of Empirical Results

The results reveal a spectrum of trade-offs: SMEs prioritize speed at the expense of documentation rigor, while enterprises prioritize compliance despite delays. Effective integration strategies depend on organizational context, which aligns findings with the research questions. Table 4.7 synthesizes strategies that cut across both SMEs and enterprises. Table 4.8 presents the roles and interactions that facilitated effective collaboration between developers and auditors.

Table 4.7: Cross-Industry Strategies for Agile–ISO 27001 Balance

Strategy	Finance (P1, P7)	Healthcare (P2, P12)	SMEs/Startups (P5, P9)	Non-Profits (P10)
Automation	CI/CD gates, Jira plugins	SBOM generation	Shift-left threat modeling	Open-source SIEM (Wazuh)
Cultural Shifts	Security Champions	Compliance Poker	Gamified badges	Volunteer mentors
Tooling	AI risk scoring (P3)	GDPR-ISO matrices (P12)	DevSecOps pipelines (P9)	Simplified checklists
Audit Alignment	Hybrid models (P7)	Live dashboards (P2)	Mini-audits per sprint (P5)	Auto-generated evidence

Table 4.8: Cross-Functional Collaboration

Key Insight	Participant Evidence	Industry Impact
Auditor Involvement in Sprints	"We invite auditors to sprint reviews to show live dashboards." (P8)	
	"They stopped asking for Gantt charts after seeing real-time risk maps." (P2)	40% faster audit approvals (P2).
Unified Compliance Frameworks	"GDPR-ISO matrices eliminated redundant controls." (P12)	
	"We mapped HIPAA to Annex A for clarity." (P2)	70% fewer redundant controls (P12).

5

Discussion

The research question guiding this study is: "How does the integration of ISO 27001 influence Agile software development practices in organizations of different sizes?" In response, our findings show distinct patterns based on organizational scale. In SMEs, ISO 27001 integration tends to produce lightweight, iterative security processes, such as incremental documentation during Agile sprints, risk-driven checklists, and gamified security champion roles that embed compliance into daily workflows with minimal overhead. In contrast, in MNEs, the standard drives formalized, technology-enabled approaches: these organizations implement automated compliance tools (e.g., CI/CD pipelines with integrated security scans), compliance-as-code frameworks, and centralized governance structures to align Agile processes with ISO 27001 controls at scale. Crucially, both contexts demonstrate that agility and compliance coexist: When security is treated as a shared responsibility and processes are adapted to organizational context, Agile teams can innovate rapidly while meeting rigorous ISO requirements.

Building on these findings, the chapter explores the tensions between Agile methodologies and ISO 27001 compliance and how organizations reconcile them through context-specific strategies. By synthesizing insights from the TechSME (SME) and BankCorp (MNE) case studies and framing them through sociotechnical systems theory and Lean security principles, we interpret how these adaptations allow organizations to balance flexibility with control.

5.1 Reconciling Flexibility and Compliance

This study investigates the research question: *"How does the integration of ISO 27001 influence Agile software development practices in organizations of different sizes?"* In brief, the integration of ISO 27001 influences Agile practices in several key ways:

1. Increased documentation requirements: Agile teams must balance lightweight, iterative documentation with ISO 27001's rigorous documentation and audit trails (Valdés-Rodríguez et al., 2023; Dumont et al., 2021).

2. Enhanced risk management processes: ISO 27001 mandates structured risk assessments, influencing Agile teams to integrate systematic risk management within Agile iterations (Interview P6, P7).

3. Expanded DoD: ISO 27001 compels Agile teams to explicitly incorporate security criteria into their acceptance testing, making compliance part of regular sprint activities (Interview P9).

4. Formalized change management and controls: Agile flexibility is moderated by ISO 27001's requirements for formal approval processes and strict separation of environments (Interview P12).

5. Role adjustments and responsibilities: New or expanded roles, such as security champions or compliance officers, are introduced to manage ISO requirements without overly burdening Agile teams (Interview P7).

6. Cultural shift towards security awareness: Teams experience a cultural transition from viewing security as a barrier to integrating it as a shared responsibility, improving overall security consciousness (Interviews P3, P7).

A summary of these influences, organized by Agile practice area and organizational context, is presented in Table 6.1 in Chapter 6.

5.2 Strategic Adaptations in Practice

Organizations strategically adapt their Agile practices to reconcile ISO 27001 compliance with agility. SMEs, exemplified by TechSME, adopt lightweight, iterative compliance practices to mitigate resource constraints. These adaptations include:

- Gamified security champion roles to increase engagement (Interview P6).
- Incremental documentation during retrospectives, reducing upfront overhead (Interview P3).
- Use of open-source tools like Trivy and Wazuh to affordably manage security scans (Interview P3).

In contrast, larger organizations like BankCorp utilize automation and structured governance models to scale compliance efforts:

- Automation of compliance tasks using integrated SAST/DAST tools and CI/CD pipelines, significantly reducing manual workload (Interview P9).
- AI-driven compliance checks and centralized governance ensuring consistency and audit readiness (Interview P12).

Despite these differing approaches, both SMEs and MNEs successfully integrate compliance and agility by adapting ISO 27001 processes to their operational contexts.

5.3 The Role of Organizational Culture

Organizational culture is pivotal in the successful integration of ISO 27001 within Agile practices. Initially, Agile teams may perceive ISO 27001 compliance as restrictive. However, a deliberate cultural shift facilitated through targeted interventions helps mitigate resistance and embed security compliance into Agile practices:

- SMEs such as TechSME use cultural interventions like gamification and role rotation, which foster grassroots security ownership (Interview P6).
- Larger enterprises like BankCorp employ structured, mandatory training sessions and regular compliance reviews to build a proactive security culture (Interview P7).

In both organizational contexts, cultivating a culture that views compliance as an integral, shared responsibility significantly reduces resistance, enhances compliance, and sustains Agile flexibility. These cultural transformations are essential in harmonizing Agile methodologies with ISO 27001 standards across organizations of varying sizes.

5.4 Implications for Practice

Smaller organizations should adopt flexible and adaptable processes like iterative documentation and shared security roles to ensure compliance without compromising agility. Organizations should invest in automation and specialized positions such as DevSecOps engineers to achieve compliance at scale while maintaining Agile throughput. This framework reflects the recommendations of (Asprion et al., 2023) for "adaptive governance," which states that compliance measures should be flexible and change with project situations rather than be rigid.

5.5 Methodological Reflections: Reliability and Validity

Methodological rigor was ensured through:

- Triangulation: Cross-verifying findings across interviews, documents, and observations mitigated single-source bias. For instance, interview claims about automated compliance were validated against audit reports and CI/CD logs.
- Member Checking: The preliminary findings were shared with participants to confirm interpretive accuracy (Creswell and Poth, 2016).
- Researcher Reflexivity: Continuous self-assessment minimized subjective biases, particularly during observational data collection.

6

Conclusion

In conclusion, the study shows that every setting requires a tailored solution. Whether the specific situation is an SME or a large enterprise, the enforceability of ISO/IEC 27001 and agile methodology is not mutually exclusive and can be addressed through customized approaches. Simplifying documentation procedures and promoting the integration of security practices in the team. For example, TechSME introduced quick checklists per sprint and made security duties part of everyday activities, answering the research question for organizations of this size: By implementing lean practices and fostering cultural engagement, small businesses can achieve agility and security compliance. Focusing on cultural adoption rather than excessive paperwork enables SMEs to be responsive while maintaining ISO 27001 requirements. The bank integrated security requirements into its DevOps pipeline through CaC and hired specialist liaisons to facilitate communication between Agile and audit teams. On the other hand, large organizations addressed this by developing governance frameworks and using tools that systematically ensure ISO compliance with minimal manual administration.

In both contexts, the trade-off was mitigated by treating ISO 27001 not as an obstacle but as a design requirement. Agile artifacts (user stories, sprints) were mapped directly to ISO clauses. This transformation, outlined in the proposed integration framework, illustrates the core finding. The rigidity of compliance and the fluidity of Agile need not conflict; instead, they form a sociotechnical cycle where each informs the other. In answering the research question explicitly, organizations must align their

social processes (roles, culture, communication) and technical processes (tools, automation) to build security into the Agile working method. Doing so allows teams to deliver rapidly and meet ISO 27001 standards.

This conclusion synthesizes the practical and theoretical contributions. It confirms that Lean Security and sociotechnical alignment are effective lenses for resolving the Agile-compliance dilemma. Future work could test the framework in other industries or measure its impact over time. Nonetheless, the evidence gathered here provides clear guidance, by answering the central question, we show that innovation and information security can be balanced successfully with tailored practices, from sprint-based risk reviews to AI-driven audit checks.

Table 6.1: Influences of ISO 27001 Integration on Agile Practices

Agile Practice	Influence of ISO 27001	SME Adaptations (TechSME)	MNE Adaptations (BankCorp)
Documentation	Requires formal and traceable documentation	Incremental documentation during retrospectives	Automated logs, audit trails via CI/CD
Risk Management	Structured risk assessment integrated into Agile cycles	Lightweight checklists, risk-driven stories	Automated scanning within pipelines
DoD	Expanded to include security and compliance criteria	Compliance checkpoints in sprints	Security gates in CI/CD and release pipelines
Change Management	Demands controlled change approval and traceability	Lean change approval integrated into Agile boards	Centralized governance and gated deployments
Roles and Responsibilities	Introduces compliance-focused roles to Agile teams	Gamified "security champion" roles	Dedicated compliance and security officers
Organizational Culture	Fosters security awareness as a shared team value	Informal training and culture-based engagement	Formalized programs, audits, and training

6.1 Summary of Key Findings

This study explicitly addresses the research question: *"How does the integration of ISO 27001 influence Agile software development practices in organizations of different sizes?"* The findings, summarized in Table 6.1, highlight that ISO 27001 significantly shapes Agile practices across six primary dimensions: documentation, risk management, the DoD, change management, team roles and responsibilities, and organizational culture.

SMEs and MNEs adopt distinct adaptation strategies due to differing resource availability and organizational contexts. SMEs tend toward lightweight, iterative approaches such as incremental documentation, informal security roles, and simplified compliance checkpoints to maintain

agility without compromising compliance. In contrast, MNEs leverage formalized processes, automation through advanced CI/CD pipelines, dedicated security roles, and structured governance frameworks to scale Agile practices while fulfilling rigorous ISO requirements.

These findings demonstrate that while ISO 27001 integration introduces complexity, it ultimately enhances Agile practices by embedding security as a core component of organizational culture and development processes. The identified strategies provide practical insights for organizations striving to balance security compliance and Agile flexibility effectively.

6.2 Contributions

This research contributes significantly to academic discourse and practical application in industry. Theoretically, it adds to understanding Agile-compliance dynamics by incorporating sociotechnical systems theory into the discussion. This perspective highlights the interconnection of technical controls, human behavior, and organizational norms, which makes it clear that a holistic approach is needed for effective integration. In practical terms, the research suggests a framework that can be tailored to an organization's specific needs in various sizes, industries, and regulatory environments. This framework provides practical recommendations that can be used by small businesses and large corporations to manage agility and compliance effectively.

6.3 Limitations and Future Research

While this investigation advances the understanding of ISO 27001–Agile integration dynamics, its interpretive boundaries necessitate explicit articulation to calibrate the epistemological weight of findings.

Sample Representational Constraints: Focusing on a fintech SME and a regulated financial enterprise limits generalizability. Patterns observed may not resonate with organizations in other sectors or jurisdictions. Access and Data Sensitivity Organizational gatekeeping limited access to real-time security incident logs and unredacted retrospective sprint reviews, creating asymmetry in observational depth. Interpretive Subjectivity Despite triangulating interview data, field notes, and artifacts, the constructivist approach inherently embeds researcher positionality. Bracketing techniques were used, yet bias may persist. Short-Term Temporal Focus The study captures short-term integration dynamics but cannot assess

second-order effects such as certification maintenance costs or evolving threat landscapes.

Future Research Directions: Further studies could triangulate quantitative metrics with ethnographic data across industries and geographies or explore post-certification cultural assimilation over multi-year timelines.

6.4 Final Statement

In an era of rapid digital transformation, integrating Agile with ISO 27001 is not merely a technical challenge but a sociotechnical endeavor requiring alignment of tools, processes, and culture. This study demonstrates that automation, cultural adaptation, and hybrid models can reconcile agility with compliance, offering a roadmap for organizations navigating this balance. Future research must address sector-specific needs and emerging technologies to stay ahead of evolving cyber threats.

Bibliography

Abid, M. F. (2025). Cross-industry application development strategies for optimizing e-commerce, retail, banking, and telecom systems. *International Journal of Finance (IJFIN)*, *38*(1), 1–8. https://www.researchgate.net/profile/Research-Pub/publication/386579319_Cross-Industry_Application_Development_Strategies_for_Optimizing-E-Commerce_Retail_Banking_and_Telecom_Systems/links/6757cac234301c1fe949c331/Cross-Industry-Application-Development-Strategies-for-Optimizing-E-Commerce-Retail-Banking-and-Telecom-Systems.pdf

Adams, T. R. (2019). *Continuous Integration! You Keep Using Those Words. I Do Not Think They Mean What You Think They Mean* (tech. rep. No. LA-UR-19-20745). Los Alamos National Laboratory (LANL). Los Alamos, NM, United States. https://www.osti.gov/biblio/1493522

Akhtar, N. S. I. (2025). *Inter cloud security framework for handling of data* [Doctoral dissertation, National University of Sciences and Technology]. https://repositories.nust.edu.pk/xmlui/bitstream/handle/123456789/49984/PhD-IS-14.pdf?sequence=1&isAllowed=y

Asprion, P., Giovanoli, C., Scherb, C., & Bhat, S. (2023). Agile management in cybersecurity. *Society 5.0 2023 (EPiC Series in Computing)*, *93*, 21–32.

Assal, H., & Chiasson, S. (2019). Security in the software development lifecycle. *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems*, 1–13.

Axon, L., Fletcher, K., Scott, A. S., Stolz, M., Hannigan, R., Kaafarani, A. E., & Creese, S. (2022). Emerging cybersecurity capability gaps in the industrial internet of things: Overview and research agenda. *Digital Threats: Research and Practice*, *3*(4), 1–27. https://doi.org/10.1145/3503920

Baxter, G., & Sommerville, I. (2011). Socio-technical systems: From design methods to systems engineering. *Interacting with Computers*, *23*(1), 4–17.

Beck, K., Beedle, M., van Bennekum, A., Cockburn, A., Cunningham, W., Fowler, M., & Thomas, D. (2001). Manifesto for agile software development.

Braun, V., & Clarke, V. (2006). Using thematic analysis in psychology. *Qualitative research in psychology*, *3*(2), 77–101.

Bremer, C., Rylander Eklund, A., & Elmquist, M. (2025). Scaling or growing agile? proposing a manifesto for agile organization development. *Journal of Organization Design*, *14*(1), 23–34. https://doi.org/10.1007/s41469-024-00179-9

Brezav s cek, A., & Baggia, A. (2025). Recent trends in information and cyber security maturity assessment: A systematic literature review. *Systems*, *13*(1), 52. https://doi.org/10.3390/systems13010052

Ceko, E. (2024). A worldwide iso standards trend perspective analysis. https://crj.cit.edu.al/wp-content/uploads/2014/10/Corrected_Thesis_3.pdf

Creswell, J. W., & Poth, C. N. (2016). *Qualitative inquiry and research design: Choosing among five approaches*. Sage publications.

Culot, G., Nassimbeni, G., Podrecca, M., & Sartor, M. (2021). The iso/iec 27001 information security management standard: Literature review and theory-based research agenda. *The TQM Journal*, *33*(7), 76–105. https://doi.org/10.1108/TQM-09-2020-0202

Drissi, S., Chergui, M., & Khatar, Z. (2025). A systematic literature review on risk assessment in cloud computing: Recent research advancements. *IEEE Access*. https://doi.org/10.1109/ACCESS.2025.3561123

Duarte, H. M. (2020). *Agile adoption best practices in canadian banking* [Doctoral dissertation]. Heriot-Watt University. https://www.ros.hw.ac.uk/handle/10399/4274

Dumont, J. R., Castro, D. E., Muñoz, A. V., & Auqui, J. A. (2021). The integration of agile and iso 27001: Challenges and best practices. *Journal of Information Security*, *10*(2), 135–152.

Fitzgerald, B., & Stol, K. J. (2017). Continuous software engineering: A roadmap and agenda. *Journal of Systems and Software*, *123*, 176–189. https://doi.org/10.1016/j.jss.2015.06.063

Folorunso, A., Adewa, A., Babalola, O., & Nwatu, C. E. (2024). A governance framework model for cloud computing: Role of ai, security, compliance, and management. *World Journal of Advanced Research and Reviews*, *24*(02), 1969–1982.

Fowler, M., Highsmith, J., et al. (2001). The agile manifesto. *Software development*, *9*(8), 28–35.

Gaggero, G. B., Armellin, A., Girdinio, P., & Marchese, M. (2024). An iec 62443-based framework for secure-by-desing energy communities. *IEEE Access*. https://doi.org/10.1109/ACCESS.2024.3492316

Huhtinen, V. (2021). *Iso 27001 standardization of the existing isms in a software industry sme* [Master's thesis, LUT University].

Iryna, C., & Anastasiia, H. (2024). Transformations in the global risk landscape: Considerations for strategic risk management system development. *Modeling the Development of the Economic Systems*, (4), 328–337. https://doi.org/10.31891/mdes/2024-14-43

ISO/IEC. (2022). *Iso/iec 27001: Information security management systems*. International Organization for Standardization.

Kauko, J. (2025). Shifting from sales-led growth to product-led growth. https://helda.helsinki.fi/bitstreams/233bb71d-0162-42bc-886b-39d984ffca4c/download

Khadka, M., Subedi, K., & Yusof, Z. B. (2022). Developing robust data security frameworks for complex cross-domain architectures: Enhancing efficiency, real-time analytics, and decision-making capabilities. *Eigenpub Review of Science and Technology*, *4*, 15–29.

Kocot, M., & Szyma'nska, M. (2025). Using design thinking in agile organizations in the aspect of sustainable development of the organization. *Scientific Papers of Silesian University of Technology. Organization & Management / Zeszyty Naukowe Politechniki 'Sl'askiej. Seria Organizacji i Zarzadzanie*, (218). https://doi.org/10.29119/1641-3466.2025.218.19

Kuusisto, E. (2022). Approaching vuca environment with enterprise agility in government organization: Case business finland and covid-19. https://osuva.uwasa.fi/handle/10024/14079

Lopes, I. M., Guarda, T., & Oliveira, P. (2019). How iso 27001 can help achieve gdpr compliance. *2019 14th Iberian Conference on Information Systems and Technologies (CISTI)*, 1–6. https://doi.org/10.23919/CISTI.2019.8760937

McCoy, E. (2025). Cybersecurity real-world applications for the software development life cycle. *Land Forces Academy Review*, *30*(1), 148–

161. https://sciendo.com/2/v2/download/article/10.2478/raft-2025-0015.pdf

Mohd Zin, N. A., Mazlan, A. N., Arifin, N., Abdul Rahman, N., Ahmad, M., & Manaf, M. M. (2024). Applying personal scrum methodology in system development for project-based learning course. *Journal of Mathematics and Computing Science (JMCS)*, *10*(2), 64–73. https://ir.uitm.edu.my/id/eprint/113381/

Moyon, E., Astudillo, H., & Kalinowski, M. (2020). Security compliance in agile software development. *Proceedings of the 19th Brazilian Symposium on Software Quality*.

Munir, N. (2024). The impact of iso 27001 compliance on employees' information security awareness and behaviors in medium sized enterprises (mses). https://www.diva-portal.org/smash/get/diva2:1874341/FULLTEXT01.pdf

Nam, P. H. (2023). *Transforming business applications in sme by implementing low-code no-code development platforms* [Doctoral dissertation]. Vietnam University. https://epub.vgu.edu.vn/handle/dlibvgu/1689

Nurmi, P. (2024). *Enhancing iso 27001: 2022 implementation through project management* [Master's thesis, Theseus]. https://www.theseus.fi/handle/10024/863059

O'g'li, O. B. M. (2025). Iso standards and transportation of hydrogen: A review. *Scientific Journal of Mechanics and Technology*, *1*(18), 208–219. https://cyberleninka.ru/article/n/iso-standarts-and-transportation-of-hydrogen-a-review

Podrecca, M. (2023). ISO/IEC 27001: An empirical multi-method research. https://air.uniud.it/handle/11390/1252404

Prates, L., & Pereira, R. (2025). Devsecops practices and tools. *International Journal of Information Security*, *24*(1), 1–25. https://doi.org/10.1007/s10207-024-00914-z

Rindell, K., Ruohonen, J., Holvitie, J., Hyrynsalmi, S., & Leppänen, V. (2021). Security in agile software development: A practitioner survey. *Information and Software Technology*, *131*, 106488.

Sang, K. (2023). *Cybersecurity assessment model for small and medium enterprises (smes) e-commerce in kenya* [Doctoral dissertation, KCA University]. http://41.89.49.50:8080/handle/123456789/1527

Schwaber, K., & Sutherland, J. (2020). Panduan scrum. *Diakses tanggal*, *2*.

Sharma, N. K., & Dash, P. K. (2012). Effectiveness of iso 27001, as an information security management system: An analytical study of financial aspects. *Far East Journal of Psychology and Business*, *9*(3), 42–55. https://www.academia.edu/download/32005263/effectivenes_of_iso_27001.pdf

Shetty, A. D. (2023). *Enhancing information security management system using iso controls-based framework* [Doctoral dissertation, National College of Ireland].

Siponen, M., & Willison, R. (2009). Information security management standards: Problems and solutions. *Information & Management*, *46*(5), 267–270. https://doi.org/10.1016/j.im.2008.12.007

Smith, J., Johnson, L., & Brown, T. (2022). Automating security compliance in agile environments. *Journal of Information Security*, *13*(4), 45–60.

Stewart, H. (2023). *Strengthening cybersecurity in digital transformation* [Doctoral dissertation, Flinders University, College of Science and Engineering]. https://flex.flinders.edu.au/file/56e99da5-1754-45e0-8cb2-d8e2b5f843c5/1/StewartThesis2023_MasterCopy.pdf

Talib, M. A., Khelifi, A., & Ugurlu, T. (2012). Using iso 27001 in teaching information security. *IECON 2012-38th Annual Conference on IEEE Industrial Electronics Society*, 3149–3153. https://ieeexplore.ieee.org/abstract/document/6389395

Tanneru, B. (2025). Integrating security vulnerability management into agile devops pipelines. *IJSAT-International Journal on Science and Technology*, *16*(1). https://www.ijsat.org/research-paper.php?id=3153

Thool, A., & Brown, C. (2024). Securing agile: Assessing the impact of security activities on agile development. *Proceedings of the 28th International Conference on Evaluation and Assessment in Software Engineering*, 668–678. https://doi.org/10.1145/3661167.3661280

Tokerud, S., Jansen, J. N., Niemimaa, M., & Järveläinen, J. (2023). Designing extended zero trust maturity model–from technical to socio-technical. *Forty-Fourth International Conference on Information Systems, Hyderabad, India 2023*, 1–17. https://www.researchgate.net/profile/Jonna-Jaervelaeinen/publication/374757783_Designing_Extended_Zero_Trust_Maturity_Model_-_From_Technical_to_Socio-Technical/links/65a90f27f323f74ff1c84a50/Designing-Extended-Zero-Trust-Maturity-Model-From-Technical-to-Socio-Technical.pdf

Toomey, E. (2021). The project management challenges, benefits, risks and limitations of adopting agile methodologies for a multiphase erp program. https://cora.ucc.ie/handle/10468/12388

Valdés-Rodríguez, Y., Hochstetter-Diez, J., Díaz-Arancibia, J., & Cadena-Martínez, R. (2023). Towards integrating security practices in agile software development: A systematic mapping review. *Applied Sciences*, *13*(7), 4578. https://doi.org/10.3390/app13074578

Yin, R. K. (2018). Case study research and applications.

Appendices

A

Participant Consent Form (GDPR-Compliant)

Research Title:

The Influence of ISO 27001 Standards on Agile Methodology

Researcher:

Vahid Naserinia AND Sami Ullah, Stockholm University
Supervisor: Gunnar Wettergren

1. Purpose of Study

This research investigates how organizations balance ISO 27001 compliance requirements with Agile development methodologies. Your professional insights will help identify practical integration strategies.

2. What Participation Involves

- A 30-45 minute interview (virtual or in-person)
- Discussion of your experiences with Agile-ISO 27001 integration
- Optional follow-up clarification questions via email

3. Data Protection (GDPR Compliance)

- All personal data processed according to EU GDPR (2016/679)

- Data collected includes: Professional opinions (audio/text), job role, industry sector
- No personally identifiable information will be published

4. Your Rights

- Right to withdraw within 14 days of the interview
- Right to request data deletion before thesis submission date (about June 2025)
- Right to access your interview transcript
- Right to request clarification about data usage

Consent Statements

I, _____, confirm that:

☐ I have read the information sheet and understand the study purpose

☐ I voluntarily agree to participate

☐ I consent to audio recording (select one):

  ☐ Yes, with full transcription

  ☐ Yes, but only for researcher notes (no full transcription)

  ☐ No recording (notes only)

☐ I agree to anonymized quotes being used in publications

☐ I understand I may withdraw before June 2025

Participant Name: _____

Signature: _____

Date: _____

B

Semi-Structured Interview Guide

Title and Objective: Explore practical experiences, trade-offs, and innovative solutions for Balancing Agile Flexibility with ISO 27001 Compliance. (30-45 minutes)

Section 1: Background & Context (5-7 minutes)

- **Role & Experience:**
  - Can you describe your role and how it intersects with Agile and ISO 27001 compliance?
  - How long has your organization used Agile? ISO 27001? Were they adopted simultaneously?
- **Organizational Maturity:**
  - On a scale of 1-5, how would you rate your team's familiarity with ISO 27001 requirements?
  - Has ISO 27001 certification impacted Agile delivery timelines? If so, how?

Section 2: Challenges & Trade-Offs (10-12 minutes)

- **Flexibility vs Compliance:**
  - Describe a situation where Agile's speed clashed with ISO's documentation needs

  - *Probe:* Did this lead to process changes (e.g., lighter documentation)?

- **Team Resistance:**
  - Have teams pushed back against security controls? How was this addressed?
  - *Probe:* Were there mindset shifts (security as enabler) that helped?

Section 3: Security Practices (10-12 minutes)

- **Embedding Security:**
  - Walk me through security integration in your Agile process
  - *Probe:* How are security priorities balanced with feature development?
- **Tools & Automation:**
  - What tools do you use to automate compliance? How effective are they?

Section 4: Success Factors (8-10 minutes)

- **Best Practices:**
  - What's one strategy that significantly improved Agile-ISO alignment?
- **Innovations:**
  - What emerging trends could better bridge Agile and ISO 27001?

Section 5: Closing (3-5 minutes)

- Is there anything critical we haven't covered?
- Would you be open to a follow-up if needed?

C

ISO/IEC 27001:2022 Annex A Control Domains

Table C.1: Annex A Control Domains (Cited in This Thesis)

Domain	Description
A.5	Information Security Policies
A.6	Organization of Information Security
A.7	Human Resource Security
A.8	Asset Management
A.9	Access Control
A.10	Cryptography
A.11	Physical and Environmental Security
A.12	Operations Security
A.13	Communications Security
A.14	System Acquisition, Development and Maintenance
A.15	Supplier Relationships
A.16	Information Security Incident Management
A.17	Information Security Aspects of Business Continuity Management
A.18	Compliance

D

Key ISO/IEC 27001:2022 Clauses

Table D.1: ISO/IEC 27001:2022 (Clauses Cited in This Thesis)

Clause	Requirement (summarized)
7	Support: The organization must determine and provide the resources, awareness, communication, and documented information necessary for the ISMS.
8	Operation: The organization must plan, implement, and control the processes needed to meet ISMS requirements, including risk assessments and treatment.
A.10.1.1	Cryptographic controls: Information systems shall be protected by cryptographic measures to ensure confidentiality, integrity, and availability.